

**CarbonLedger**  
AI-Powered Supply Chain Emissions Auditor  
Software Requirements Specification

CarbonLedger Engineering — Prepared by the Office of the CTO  
Version 1.0 · July 29, 2026

**Contents**

0.1 Document Control . . . . . 6  
    0.1.1 Revision History . . . . . 6  
    0.1.2 Distribution List . . . . . 6

**1 1. Introduction 8**  
    1.1 1.1 Purpose . . . . . 8  
    1.2 1.2 Scope . . . . . 8  
    1.3 1.3 Business Objectives . . . . . 9  
    1.4 1.4 Product Vision . . . . . 9  
    1.5 1.5 Intended Audience . . . . . 9  
    1.6 1.6 Definitions . . . . . 10  
    1.7 1.7 Acronyms . . . . . 11  
    1.8 1.8 References . . . . . 11  
    1.9 1.9 Document Overview . . . . . 12

**2 2. Overall Description 13**  
    2.1 2.1 Product Perspective . . . . . 13  
    2.2 2.2 System Overview . . . . . 13  
    2.3 2.3 Business Process . . . . . 14  
    2.4 2.4 Operating Environment . . . . . 14  
    2.5 2.5 System Context Diagram — Actor View . . . . . 16  
    2.6 2.6 Stakeholders . . . . . 17  
    2.7 2.7 User Roles . . . . . 17  
    2.8 2.8 Assumptions . . . . . 18  
    2.9 2.9 Dependencies . . . . . 18  
    2.10 2.10 Constraints . . . . . 18  
    2.11 2.11 Business Rules . . . . . 19

|                                                                       |           |
|-----------------------------------------------------------------------|-----------|
| 2.122.12 Future Enhancements . . . . .                                | 19        |
| <b>3 3. Functional Requirements</b>                                   | <b>20</b> |
| 3.1 3.1 Module: Authentication & Authorization . . . . .              | 20        |
| 3.1.1 FR-AUTH-01 — User Registration and Organization Creation . .    | 20        |
| 3.1.2 FR-AUTH-02 — Login with Multi-Factor Authentication . . . .     | 20        |
| 3.1.3 FR-AUTH-03 — Role-Based Access Control (RBAC) . . . . .         | 21        |
| 3.2 3.2 Module: Organization Management . . . . .                     | 22        |
| 3.2.1 FR-ORG-01 — Organization Profile & Facility Configuration . . . | 22        |
| 3.2.2 FR-ORG-02 — User Invitation and Role Assignment . . . . .       | 22        |
| 3.3 3.3 Module: Supplier Management . . . . .                         | 22        |
| 3.3.1 FR-SUP-01 — Supplier Master Data Management . . . . .           | 22        |
| 3.3.2 FR-SUP-02 — Supplier Portal for Self-Submitted Data . . . . .   | 23        |
| 3.3.3 FR-SUP-03 — Supplier Emissions Dashboard . . . . .              | 23        |
| 3.3.4 FR-DOC-01 — Multi-Format Document Upload . . . . .              | 24        |
| 3.3.5 FR-DOC-02 — Document Status Tracking . . . . .                  | 24        |
| 3.4 3.5 Module: OCR Extraction . . . . .                              | 24        |
| 3.4.1 FR-OCR-01 — Optical Character Recognition Pipeline . . . . .    | 24        |
| 3.5 3.6 Module: AI Data Extraction . . . . .                          | 25        |
| 3.5.1 FR-AI-01 — Document Classification . . . . .                    | 25        |
| 3.5.2 FR-AI-02 — Structured Line-Item Extraction . . . . .            | 25        |
| 3.5.3 FR-AI-03 — Natural Language Query Assistant (Chat) . . . . .    | 26        |
| 3.6 3.7 Module: Emission Factor Matching . . . . .                    | 26        |
| 3.6.1 FR-EF-01 — Semantic Emission Factor Matching . . . . .          | 26        |
| 3.6.2 FR-EF-02 — Emission Factor Database Management . . . . .        | 27        |
| 3.7 3.8 Module: Carbon Footprint Calculation . . . . .                | 27        |
| 3.7.1 FR-CALC-01 — Scope 1 Emissions Calculation . . . . .            | 27        |
| 3.7.2 FR-CALC-02 — Scope 2 Emissions Calculation . . . . .            | 28        |
| 3.7.3 FR-CALC-03 — Scope 3 Emissions Calculation . . . . .            | 28        |
| 3.7.4 FR-CALC-04 — CBAM-Specific Embedded Emissions Calculation       | 28        |
| 3.7.5 FR-ANLT-01 — Organization Emissions Dashboard . . . . .         | 29        |
| 3.7.6 FR-ANLT-02 — Carbon Hotspot Detection . . . . .                 | 29        |
| 3.7.7 FR-ANLT-03 — Emission Trend Forecasting . . . . .               | 29        |
| 3.8 3.10 Module: AI Recommendations . . . . .                         | 29        |
| 3.8.1 FR-REC-01 — Emission Reduction Recommendation Engine . . .      | 29        |
| 3.9 3.11 Module: Reporting (CBAM / GHG Protocol) . . . . .            | 30        |
| 3.9.1 FR-RPT-01 — GHG Protocol Corporate Report Generation . . . .    | 30        |
| 3.9.2 FR-RPT-02 — CBAM Quarterly/Annual Declaration Report . . . .    | 30        |
| 3.9.3 FR-RPT-03 — Report Submission and Immutability Lock . . . . .   | 31        |
| 3.103.12 Module: Notification System . . . . .                        | 31        |
| 3.10.1FR-NOTIF-01 — Event-Driven Notifications . . . . .              | 31        |
| 3.113.13 Module: Audit Logs . . . . .                                 | 31        |
| 3.11.1FR-AUD-01 — Immutable Audit Trail . . . . .                     | 31        |
| 3.123.14 Module: Administration . . . . .                             | 32        |
| 3.12.1FR-ADM-01 — Super Admin Cross-Tenant Operations Console . .     | 32        |
| 3.133.15 Module: Settings & User Profile . . . . .                    | 32        |
| 3.13.1FR-SET-01 — User Profile and Preferences . . . . .              | 32        |
| 3.13.2FR-SET-02 — Organization Integration Settings . . . . .         | 32        |

|                                                              |           |
|--------------------------------------------------------------|-----------|
| 3.143.17 Representative Use Cases . . . . .                  | 34        |
| 3.14.1UC-01: Generate a Quarterly CBAM Declaration . . . . . | 34        |
| 3.14.2UC-02: Onboard a New Manufacturing Facility . . . . .  | 35        |
| 3.14.3UC-03: Resolve a Flagged Emission Anomaly . . . . .    | 35        |
| 3.153.18 Sample End-to-End Workflow (Illustrative) . . . . . | 36        |
| <b>4 4. External Interface Requirements</b>                  | <b>37</b> |
| 4.1 4.1 User Interface Requirements . . . . .                | 37        |
| 4.2 4.2 REST API Specifications . . . . .                    | 37        |
| 4.2.1 4.2.1 Authentication API . . . . .                     | 37        |
| 4.2.2 4.2.2 Document API . . . . .                           | 38        |
| 4.2.3 4.2.3 Supplier API . . . . .                           | 38        |
| 4.2.4 4.2.4 Emission API . . . . .                           | 38        |
| 4.2.5 4.2.5 Reporting API . . . . .                          | 39        |
| 4.2.6 4.2.6 Common Error Response Format . . . . .           | 39        |
| 4.2.7 4.2.7 HTTP Status Codes Used . . . . .                 | 40        |
| 4.2.8 4.2.8 Application Error Codes (excerpt) . . . . .      | 40        |
| 4.3 4.3 Communication Interfaces . . . . .                   | 41        |
| 4.4 4.4 Hardware Requirements . . . . .                      | 41        |
| 4.5 4.5 Software Interfaces . . . . .                        | 41        |
| 4.6 4.6 Third-Party ERP Integrations . . . . .               | 41        |
| <b>5 5. Non-Functional Requirements</b>                      | <b>43</b> |
| 5.1 5.1 Performance . . . . .                                | 43        |
| 5.2 5.2 Scalability . . . . .                                | 43        |
| 5.3 5.3 Availability . . . . .                               | 43        |
| 5.4 5.4 Reliability . . . . .                                | 43        |
| 5.5 5.5 Usability . . . . .                                  | 44        |
| 5.6 5.6 Accessibility . . . . .                              | 44        |
| 5.7 5.7 Maintainability . . . . .                            | 44        |
| 5.8 5.8 Portability . . . . .                                | 44        |
| 5.9 5.9 Security . . . . .                                   | 44        |
| 5.105.10 Compliance . . . . .                                | 44        |
| 5.115.11 Backup . . . . .                                    | 45        |
| 5.125.12 Recovery . . . . .                                  | 45        |
| 5.135.13 Logging . . . . .                                   | 45        |
| 5.145.14 Monitoring . . . . .                                | 45        |
| 5.155.15 Non-Functional Requirements Summary Table . . . . . | 45        |
| <b>6 6. Data Requirements</b>                                | <b>48</b> |
| 6.1 6.1 Entity Relationship Diagram . . . . .                | 48        |
| 6.2 6.2 Database Tables — Structural Summary . . . . .       | 49        |
| 6.3 6.3 Normalization . . . . .                              | 49        |
| 6.4 6.4 Data Validation Rules . . . . .                      | 50        |
| 6.5 6.5 Data Dictionary (Excerpt) . . . . .                  | 50        |
| 6.6 6.6 Sample Records (Illustrative) . . . . .              | 50        |
| 6.7 6.7 Data Retention . . . . .                             | 51        |

|           |                                                                          |           |
|-----------|--------------------------------------------------------------------------|-----------|
| <b>7</b>  | <b>7. System Models</b>                                                  | <b>52</b> |
| 7.1       | 7.1 Use Case Diagram . . . . .                                           | 52        |
| 7.2       | 7.2 Class Diagram (Core Domain Model) . . . . .                          | 53        |
| 7.3       | 7.3 Activity Diagram — Document Processing Pipeline . . . . .            | 55        |
| 7.4       | 7.4 Component Diagram . . . . .                                          | 56        |
| 7.5       | 7.5 Deployment Diagram . . . . .                                         | 56        |
| 7.6       | 7.6 State Diagram — Report Lifecycle . . . . .                           | 58        |
| 7.7       | 7.7 Data Flow Diagram — Level 0 (Context) . . . . .                      | 59        |
| 7.8       | 7.8 Data Flow Diagram — Level 1 (Major Processes) . . . . .              | 59        |
| 7.9       | 7.9 Data Flow Diagram — Level 2 (Extraction & Matching Detail) . . . . . | 59        |
| 7.10      | 7.10 Package Diagram . . . . .                                           | 60        |
| 7.11      | 7.11 High-Level Architecture Diagram . . . . .                           | 60        |
| <b>8</b>  | <b>8. Security Requirements</b>                                          | <b>61</b> |
| 8.1       | 8.1 Authentication . . . . .                                             | 61        |
| 8.2       | 8.2 Authorization . . . . .                                              | 61        |
| 8.3       | 8.3 JWT & Token Management . . . . .                                     | 61        |
| 8.4       | 8.4 OAuth . . . . .                                                      | 61        |
| 8.5       | 8.5 RBAC Enforcement Matrix (Excerpt) . . . . .                          | 61        |
| 8.6       | 8.6 Encryption . . . . .                                                 | 62        |
| 8.7       | 8.7 Data Protection . . . . .                                            | 62        |
| 8.8       | 8.8 GDPR . . . . .                                                       | 62        |
| 8.9       | 8.9 Audit Logs . . . . .                                                 | 62        |
| 8.10      | 8.10 Threat Model (Summary) . . . . .                                    | 63        |
| 8.11      | 8.11 OWASP Top 10 (2021) Mitigation Mapping . . . . .                    | 63        |
| 8.12      | 8.12 API Security . . . . .                                              | 64        |
| 8.13      | 8.13 Secure File Upload . . . . .                                        | 64        |
| <b>9</b>  | <b>9. Performance &amp; Quality</b>                                      | <b>65</b> |
| 9.1       | 9.1 Availability, Scalability, and Fault Tolerance . . . . .             | 65        |
| 9.2       | 9.2 Load Balancing & Caching . . . . .                                   | 65        |
| 9.3       | 9.3 Performance Benchmarks . . . . .                                     | 65        |
| 9.4       | 9.4 Quality Metrics & Code Quality . . . . .                             | 65        |
| 9.5       | 9.5 Monitoring & Observability Architecture . . . . .                    | 66        |
| 9.6       | 9.6 AI / ML Pipeline Architecture . . . . .                              | 66        |
| 9.7       | 9.7 Disaster Recovery Plan . . . . .                                     | 66        |
| 9.8       | 9.8 Capacity Planning (Launch-Year Assumptions) . . . . .                | 66        |
| 9.9       | 9.9 Cost Assumptions (Illustrative, Non-Binding) . . . . .               | 67        |
| 9.10      | 9.10 Future Roadmap (Indicative) . . . . .                               | 67        |
| <b>10</b> | <b>10. Acceptance Criteria</b>                                           | <b>68</b> |
| 10.1      | 10.1 Functional Acceptance . . . . .                                     | 68        |
| 10.2      | 10.2 Performance Acceptance . . . . .                                    | 68        |
| 10.3      | 10.3 Security Acceptance . . . . .                                       | 68        |
| 10.4      | 10.4 Integration Testing . . . . .                                       | 68        |
| 10.5      | 10.5 User Acceptance Testing (UAT) . . . . .                             | 68        |
| 10.6      | 10.6 Regression Testing . . . . .                                        | 68        |
| 10.7      | 10.7 AI Model Validation . . . . .                                       | 69        |

|                                                              |           |
|--------------------------------------------------------------|-----------|
| 10.810.8 Deployment Acceptance . . . . .                     | 69        |
| <b>11 11. Appendices</b>                                     | <b>70</b> |
| 11.111.1 Glossary . . . . .                                  | 70        |
| 11.211.2 References . . . . .                                | 70        |
| 11.311.3 Revision History . . . . .                          | 70        |
| 11.411.4 Risk Register . . . . .                             | 71        |
| 11.511.5 Requirement Traceability Matrix (Excerpt) . . . . . | 72        |
| 11.611.6 Assumptions (Consolidated) . . . . .                | 73        |
| 11.711.7 Future Scope . . . . .                              | 73        |
| 11.811.8 Abbreviations . . . . .                             | 73        |
| 11.911.9 Approval . . . . .                                  | 74        |

## 0.1 Document Control

**Document Title:** Software Requirements Specification — CarbonLedger AI-Powered Supply Chain Emissions Auditor **Document Standard:** IEEE/ISO/IEC/IEEE 29148:2018 — Systems and Software Engineering, Life Cycle Processes, Requirements Engineering **Classification:** Confidential — Internal, Investor, and Enterprise-Customer Diligence Use **Status:** Baseline Draft for Review

### 0.1.1 Revision History

| Version | Date       | Author                 | Description of Changes                                     | Approved By           |
|---------|------------|------------------------|------------------------------------------------------------|-----------------------|
| 0.1     | 2026-06-02 | Product Management     | Initial outline and stakeholder list drafted               | —                     |
| 0.2     | 2026-06-18 | Solution Architecture  | Added functional decomposition and data model draft        | —                     |
| 0.3     | 2026-07-05 | Engineering Leadership | Added NFRs, security architecture, API specifications      | —                     |
| 0.9     | 2026-07-20 | Technical Writing      | Full draft compiled for internal review                    | Pending               |
| 1.0     | 2026-07-29 | Office of the CTO      | Baseline release for investor and pilot-customer diligence | CTO / Head of Product |

### 0.1.2 Distribution List

| Name / Role               | Organization                     | Purpose                         |
|---------------------------|----------------------------------|---------------------------------|
| Executive Leadership Team | CarbonLedger Inc.                | Strategic and funding decisions |
| Engineering Leadership    | CarbonLedger Inc.                | Implementation planning         |
| Pilot Customer Sponsors   | Selected manufacturers/exporters | Requirements validation         |
| Prospective Investors     | Diligence process                | Technical and market diligence  |

| Name / Role                 | Organization     | Purpose                       |
|-----------------------------|------------------|-------------------------------|
| Compliance & Legal Advisors | External counsel | GDPR / CBAM regulatory review |

# 1. Introduction

## 1.1 Purpose

This Software Requirements Specification (SRS) defines the functional, non-functional, data, interface, and security requirements for **CarbonLedger**, an AI-powered Software-as-a-Service (SaaS) platform that automates the calculation, audit, and reporting of greenhouse gas (GHG) emissions across a manufacturing organization's supply chain. This document is written in conformance with the structure and content guidance of **IEEE/ISO/IEC 29148:2018**, and is intended to serve as the authoritative reference for design, implementation, quality assurance, regulatory compliance review, and investor technical diligence.

The purpose of this document is to:

1. Establish an unambiguous, testable, and traceable set of requirements for all stakeholders.
2. Provide the engineering team with sufficient detail to design, estimate, and build the system without requiring further clarification of core scope.
3. Provide auditors, pilot customers, and compliance reviewers with a clear statement of how the system satisfies the **GHG Protocol**, **ISO 14064**, and **EU CBAM (Carbon Border Adjustment Mechanism)** reporting obligations.
4. Serve as the baseline against which acceptance testing, regression testing, and future change requests are evaluated.

## 1.2 Scope

CarbonLedger is a multi-tenant, cloud-native SaaS platform. The system will:

- Ingest heterogeneous supply-chain documents (invoices, shipping manifests, purchase orders, ERP exports, supplier master lists, logistics documents, utility bills) in PDF, image, CSV, and Excel formats.
- Apply Optical Character Recognition (OCR) and Large Language Model (LLM)-based extraction to convert unstructured/semi-structured documents into normalized, structured line-item data.
- Match extracted line items against authoritative emission-factor databases (e.g., DEFRA, EPA, GHG Protocol default factors) using embedding-based semantic search.
- Calculate **Scope 1** (direct emissions), **Scope 2** (purchased energy emissions), and **Scope 3** (value-chain emissions) greenhouse gas footprints at the organization, facility, product, and supplier level.
- Detect carbon “hotspots” — suppliers, product lines, or logistics lanes contributing disproportionately to total emissions — using statistical and machine-learning anomaly detection.
- Generate audit-ready, downloadable compliance reports mapped to the GHG Protocol Corporate Standard, ISO 14064-1, and the EU CBAM quarterly/annual declaration formats.
- Provide role-based dashboards, a natural-language query assistant, notifications, audit trails, and REST APIs for ERP integration (SAP, Oracle ERP Cloud, Mi-

crosoft Dynamics 365).

**Out of scope for this release (v1.0):** on-premises/self-hosted deployment, emissions trading/carbon-credit marketplace functionality, Scope 3 categories requiring primary supplier-submitted LCA (Life Cycle Assessment) data beyond spend/activity-based estimation, and non-English document OCR beyond the four launch languages (English, German, French, Polish).

### 1.3 1.3 Business Objectives

| ID    | Objective                                                                                                                  | Success Metric                                                                            |
|-------|----------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| BO-01 | Reduce the cost of CBAM/GHG compliance reporting for mid-market manufacturers by at least 80% versus consultant-led audits | Average customer reporting cost drops from \$50K-\$200K/year to under \$20K/year          |
| BO-02 | Cut the time-to-first-compliant-report from weeks to hours                                                                 | 90% of pilot customers produce a first draft CBAM report within 48 hours of onboarding    |
| BO-03 | Achieve audit-defensible accuracy in emissions calculations                                                                | Emission factor matching accuracy $\geq 95\%$ validated against auditor spot-checks       |
| BO-04 | Establish CarbonLedger as a system of record for supply-chain carbon data                                                  | 70% of active customers integrate at least one ERP system within 90 days                  |
| BO-05 | Build a defensible AI/ML moat around document extraction and anomaly detection                                             | Extraction model F1 score improves quarter-over-quarter via active learning feedback loop |

### 1.4 1.4 Product Vision

CarbonLedger's vision is to become the **system of record for embodied carbon in global manufacturing supply chains** — the same way that accounting software became the system of record for financial transactions. Where financial ledgers translate business activity into dollars and cents, CarbonLedger translates the same underlying business activity (purchases, shipments, energy use) into defensible, auditable units of CO<sub>2</sub>-equivalent emissions, without requiring the customer to change how they already do business or hire specialized sustainability consultants.

### 1.5 1.5 Intended Audience

| Audience                                            | Use of This Document                                                      |
|-----------------------------------------------------|---------------------------------------------------------------------------|
| Software Architects & Engineers                     | Detailed functional/non-functional/data requirements for design and build |
| QA / Test Engineers                                 | Source of testable acceptance criteria and traceability                   |
| Product Managers                                    | Scope boundary and business rule reference                                |
| Compliance & Legal Reviewers                        | Verification of GHG Protocol / ISO 14064 / CBAM / GDPR alignment          |
| Investors & Diligence Teams                         | Technical depth and defensibility assessment                              |
| Pilot Customers (Sustainability Managers, Auditors) | Validation that the system meets their operational workflow               |
| DevOps / SRE                                        | Deployment, scalability, and monitoring requirements                      |

## 1.6 1.6 Definitions

| Term              | Definition                                                                                                                                                                                               |
|-------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Scope 1 Emissions | Direct GHG emissions from sources owned or controlled by the reporting company (e.g., fuel combustion in owned vehicles or boilers)                                                                      |
| Scope 2 Emissions | Indirect GHG emissions from the generation of purchased electricity, steam, heating, or cooling consumed by the reporting company                                                                        |
| Scope 3 Emissions | All other indirect emissions occurring in a company's value chain, including purchased goods, transportation, and logistics                                                                              |
| Emission Factor   | A coefficient that converts activity data (e.g., liters of fuel, kilograms of steel) into an equivalent mass of CO <sub>2</sub> e (carbon dioxide equivalent)                                            |
| CBAM              | Carbon Border Adjustment Mechanism — an EU regulation requiring importers of certain goods (steel, aluminum, cement, fertilizers, hydrogen, electricity) to report and pay for embedded carbon emissions |

| Term    | Definition                                                                                                                                                  |
|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CO2e    | Carbon dioxide equivalent — a standardized unit expressing the global warming impact of different greenhouse gases in terms of the equivalent amount of CO2 |
| Hotspot | A supplier, product, facility, or logistics lane identified as contributing a disproportionately high share of total emissions                              |
| LLM     | Large Language Model — a machine learning model used here for document understanding and structured data extraction                                         |
| Tenant  | A distinct customer organization within the multi-tenant CarbonLedger platform                                                                              |

## 1.7 1.7 Acronyms

| Acronym     | Expansion                                          |
|-------------|----------------------------------------------------|
| SRS         | Software Requirements Specification                |
| GHG         | Greenhouse Gas                                     |
| CBAM        | Carbon Border Adjustment Mechanism                 |
| ISO         | International Organization for Standardization     |
| RBAC        | Role-Based Access Control                          |
| OCR         | Optical Character Recognition                      |
| ERP         | Enterprise Resource Planning                       |
| API         | Application Programming Interface                  |
| RTM         | Requirement Traceability Matrix                    |
| SLA         | Service Level Agreement                            |
| ESG         | Environmental, Social, and Governance              |
| MTBF / MTTR | Mean Time Between Failures / Mean Time To Recovery |
| PII         | Personally Identifiable Information                |
| JWT         | JSON Web Token                                     |
| OWASP       | Open Worldwide Application Security Project        |

## 1.8 1.8 References

| Ref   | Document                                                                                          | Publisher                                                 |
|-------|---------------------------------------------------------------------------------------------------|-----------------------------------------------------------|
| [R1]  | ISO/IEC/IEEE 29148:2018<br>— Systems and Software<br>Engineering —<br>Requirements<br>Engineering | ISO/IEC/IEEE                                              |
| [R2]  | Greenhouse Gas Protocol<br>— Corporate Accounting<br>and Reporting Standard                       | WRI / WBCSD                                               |
| [R3]  | ISO 14064-1:2018 —<br>Greenhouse gases — Part<br>1: Organizations                                 | ISO                                                       |
| [R4]  | Regulation (EU) 2023/956<br>establishing a Carbon<br>Border Adjustment<br>Mechanism               | European Commission                                       |
| [R5]  | CBAM Implementing<br>Regulation — Reporting<br>Requirements                                       | European Commission                                       |
| [R6]  | UK DEFRA Greenhouse<br>Gas Conversion Factors                                                     | UK Department for<br>Environment, Food &<br>Rural Affairs |
| [R7]  | US EPA Emission Factors<br>Hub                                                                    | US Environmental<br>Protection Agency                     |
| [R8]  | OWASP Top 10:2021                                                                                 | OWASP Foundation                                          |
| [R9]  | General Data Protection<br>Regulation (EU) 2016/679                                               | European Union                                            |
| [R10] | OAuth 2.1 / RFC 6749,<br>JSON Web Token RFC<br>7519                                               | IETF                                                      |

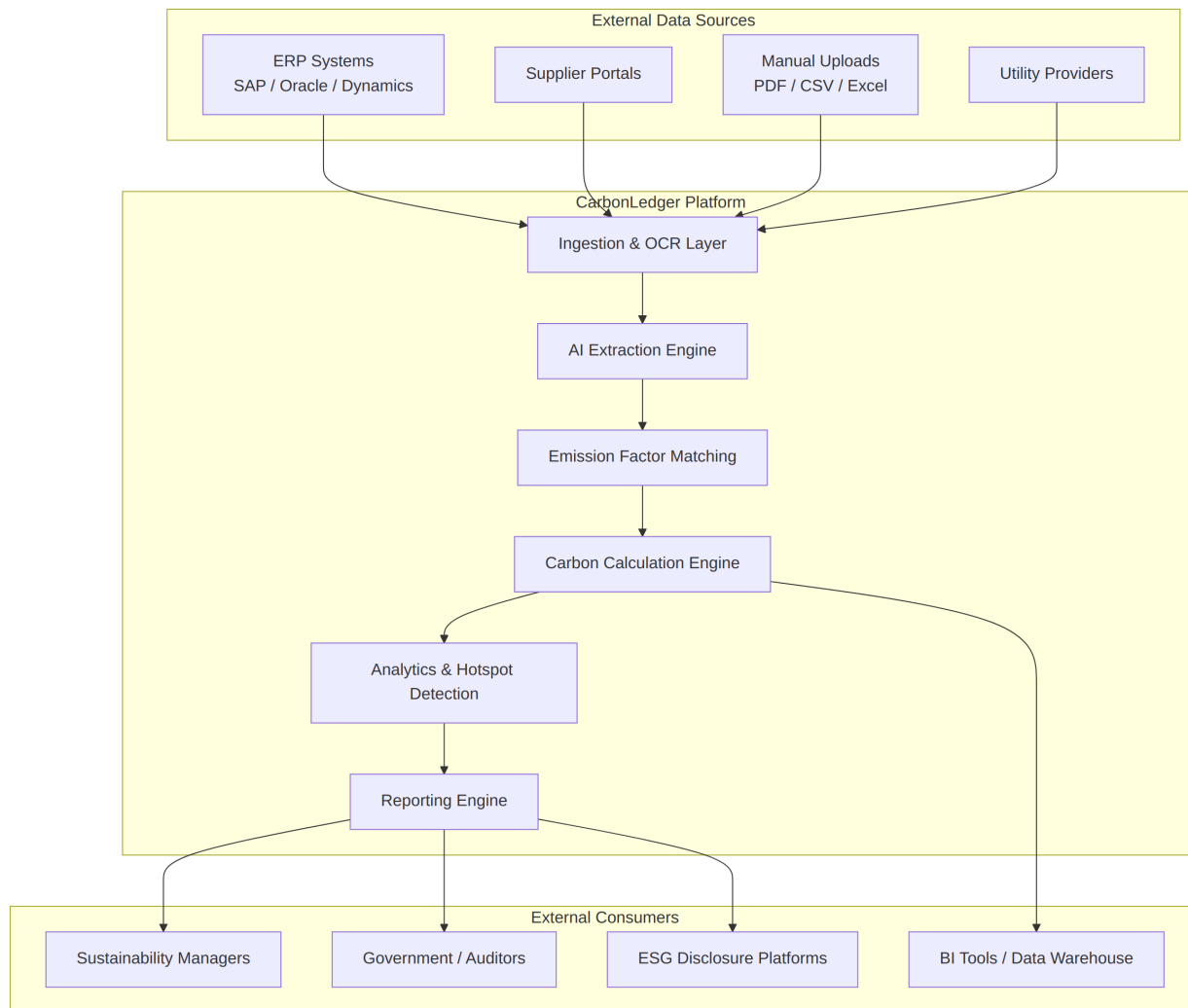
## 1.9 Document Overview

This SRS is organized into eleven chapters. Chapter 2 provides the overall product description, stakeholders, and business rules. Chapter 3 specifies functional requirements per module. Chapter 4 covers external interfaces including REST APIs. Chapter 5 defines non-functional requirements. Chapter 6 details the data model. Chapter 7 provides system models (UML/architecture diagrams). Chapter 8 covers security. Chapter 9 covers performance and quality engineering. Chapter 10 defines acceptance criteria. Chapter 11 contains appendices including the glossary, risk register, and requirement traceability matrix.

## 2. Overall Description

### 2.1 2.1 Product Perspective

CarbonLedger is a new, standalone, cloud-native SaaS product. It is not a component of an existing system, but it is designed to sit alongside and integrate with a customer's existing ERP, accounting, and procurement systems rather than replace them. Data flows into CarbonLedger from source systems (ERP exports, supplier portals, manual uploads); CarbonLedger's own outputs (emission calculations, reports, hotspot analytics) flow back out via dashboards, downloadable reports, and REST APIs that can be consumed by BI tools, ESG disclosure platforms, or the customer's own data warehouse.



**Figure 2.1 — System Context Diagram**

### 2.2 2.2 System Overview

The platform is composed of six logical layers:

- 1. **Ingestion Layer** — secure document/file upload, virus scanning, format detection, and queuing.
- 2. **AI Extraction Layer** — OCR plus LLM-based structured extraction and document classification.
- 3. **Emission Intelligence Layer** — emission-factor matching (vector search), Scope 1/2/3 calculation engine, anomaly and hotspot detection.
- 4. **Data & Storage Layer** — relational database (PostgreSQL), object storage (AWS S3), cache (Redis), vector database (ChromaDB).
- 5. **Application Layer** — FastAPI backend services exposing REST APIs consumed by the React/TypeScript frontend and by external ERP integrations.
- 6. **Presentation Layer** — role-based web dashboards, report generation/download, notifications, and a natural-language chat assistant.

2.3 2.3 Business Process

The core end-to-end business process supported by CarbonLedger is illustrated below.

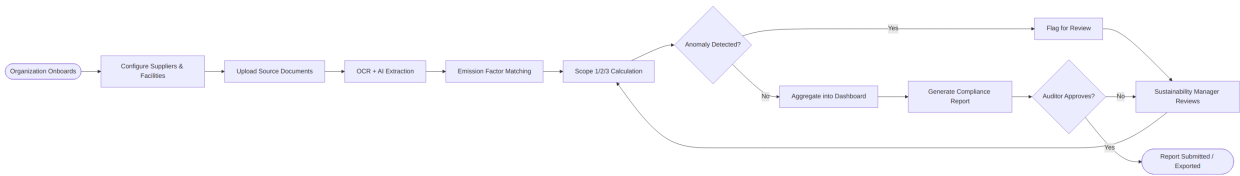


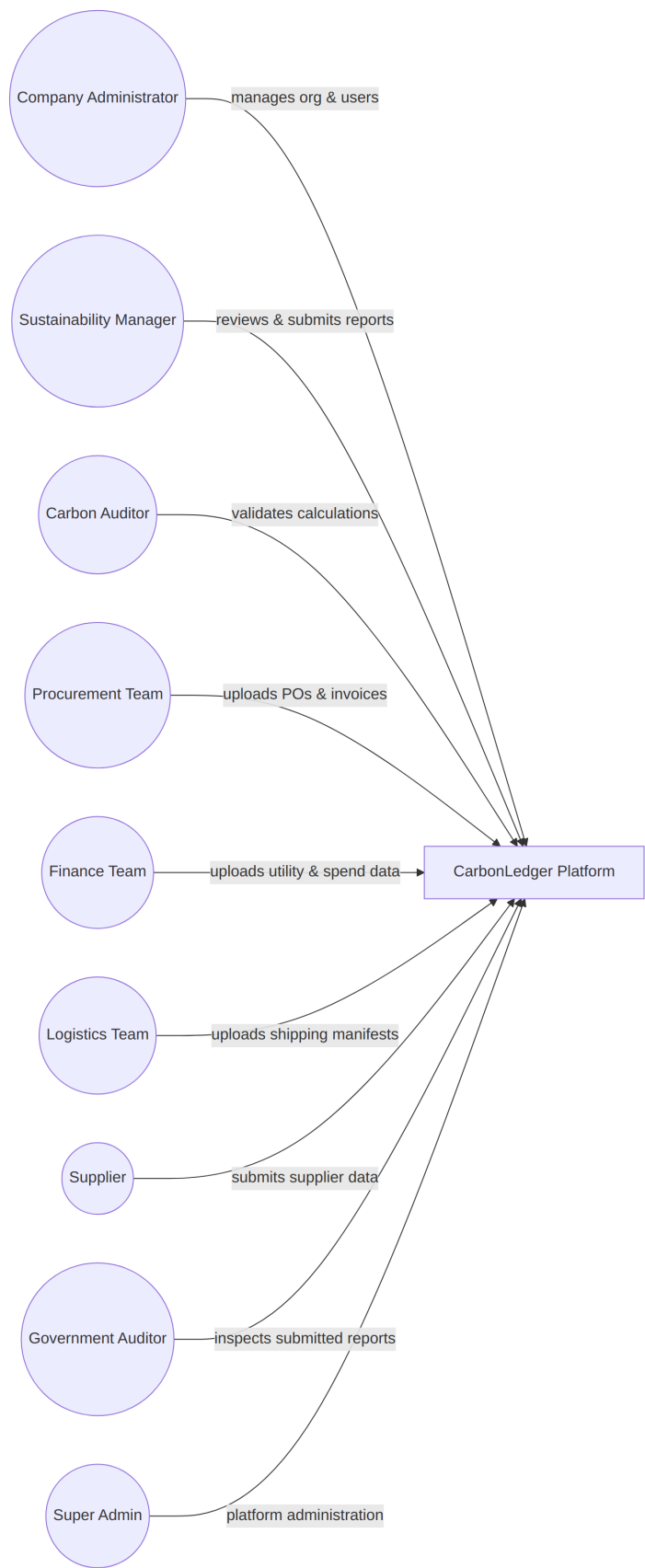
Figure 2.2 — End-to-End Business Process Flow

2.4 2.4 Operating Environment

| Layer                | Technology                                                                                         |
|----------------------|----------------------------------------------------------------------------------------------------|
| Client               | Modern evergreen browsers (Chrome, Edge, Firefox, Safari) on desktop; responsive layout for tablet |
| Frontend Framework   | React 18+, TypeScript, Tailwind CSS                                                                |
| Backend Framework    | FastAPI (Python 3.11+)                                                                             |
| Primary Database     | PostgreSQL 15+                                                                                     |
| Cache / Queue Broker | Redis 7+                                                                                           |
| Object Storage       | AWS S3 (or S3-compatible)                                                                          |
| Vector Database      | ChromaDB                                                                                           |
| ML/Analytics         | Python, Pandas, NumPy, scikit-learn                                                                |
| AI/LLM Providers     | OpenAI, Google Gemini, orchestrated via LangChain                                                  |
| Containerization     | Docker                                                                                             |
| Orchestration        | Kubernetes (Amazon EKS)                                                                            |
| Cloud Provider       | AWS (multi-AZ, single-region at launch, multi-region roadmap)                                      |
| CI/CD                | GitHub Actions                                                                                     |



2.5 2.5 System Context Diagram – Actor View



**Figure 2.3 — Actor Context Diagram****2.6 Stakeholders**

| Stakeholder                                  | Interest                                                           |
|----------------------------------------------|--------------------------------------------------------------------|
| CarbonLedger Executive Team                  | Revenue growth, retention, defensible AI moat                      |
| Engineering Team                             | Buildable, maintainable, well-specified requirements               |
| Pilot Customers<br>(Manufacturers/Exporters) | Accurate, low-effort compliance reporting                          |
| Investors                                    | Market-size validation, technical defensibility, unit economics    |
| EU Regulators (indirect)                     | Accurate, auditable CBAM declarations from covered goods importers |
| Data Protection Authorities                  | GDPR-compliant handling of business and personal data              |
| Third-Party Auditors                         | Ability to trace every reported number back to source documents    |

**2.7 User Roles**

| Role                   | Description                                               | Primary Permissions                                     |
|------------------------|-----------------------------------------------------------|---------------------------------------------------------|
| Company Administrator  | Manages the tenant organization, users, and billing       | Full org CRUD, user management, integration config      |
| Sustainability Manager | Owns the emissions reporting workflow end-to-end          | View/edit all emissions data, generate & submit reports |
| Carbon Auditor         | Internal or third-party reviewer validating calculations  | Read-only + annotation, approval workflow actions       |
| Procurement Team       | Uploads purchasing documents                              | Upload POs/invoices, view own uploads                   |
| Finance Team           | Uploads utility bills and spend data                      | Upload utility data, view Scope 2 calculations          |
| Logistics Team         | Uploads shipping/transport documents                      | Upload manifests, view Scope 3 transport data           |
| Supplier               | External party submitting their own product/process data  | Submit supplier-specific data via a restricted portal   |
| Government Auditor     | External regulator inspecting submitted CBAM declarations | Read-only access to submitted, locked reports           |

| Role        | Description                    | Primary Permissions                                        |
|-------------|--------------------------------|------------------------------------------------------------|
| Super Admin | CarbonLedger platform operator | Cross-tenant administration, system configuration, support |

## 2.8 2.8 Assumptions

- AS-01: Customers have digitized (or will digitize via upload) their invoices, POs, and shipping documents; fully paper-only operations are out of scope.
- AS-02: Emission factor databases (DEFRA, EPA, GHG Protocol) are publicly available and updated at most quarterly; the platform will ingest updates on a defined cadence.
- AS-03: Customers possess or will create a supplier master list sufficient to associate purchases with named suppliers.
- AS-04: Internet connectivity is available at all customer sites for document upload; there is no offline-first requirement in v1.0.
- AS-05: LLM API providers (OpenAI, Gemini) maintain published SLAs sufficient for production use; the platform includes provider failover.
- AS-06: Customers are the data controller for their business data; CarbonLedger acts as data processor under GDPR.

## 2.9 2.9 Dependencies

- DP-01: Availability and pricing stability of third-party LLM APIs (OpenAI, Google Gemini).
- DP-02: Continued public availability of DEFRA and EPA emission factor datasets.
- DP-03: Stability of the EU CBAM reporting schema (subject to regulatory change during the CBAM transition/definitive period).
- DP-04: AWS regional availability and managed-service SLAs (EKS, S3, RDS-compatible PostgreSQL).
- DP-05: ERP vendor API stability for SAP, Oracle ERP Cloud, and Microsoft Dynamics 365 integrations.

## 2.10 2.10 Constraints

- CN-01: All emissions calculations must be traceable to a specific source document and emission factor version (audit defensibility requirement).
- CN-02: The system must support EU data residency options for customers subject to GDPR (EU-region deployment option).
- CN-03: Report outputs must conform exactly to the current EU CBAM declaration schema in effect at time of generation.
- CN-04: The platform must operate within a target infrastructure cost envelope consistent with a mid-market SaaS pricing model (see Chapter 9 cost assumptions).
- CN-05: v1.0 supports English, German, French, and Polish document OCR only.

## 2.11 2.11 Business Rules

| ID    | Rule                                                                                                                                                                                                                            |
|-------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| BR-01 | Every calculated emission value must reference exactly one emission-factor version and one or more source documents; orphaned calculations are not permitted.                                                                   |
| BR-02 | A report cannot be marked “Submitted” until all flagged anomalies within its reporting period have been either resolved or explicitly overridden with a documented justification by a Sustainability Manager or Carbon Auditor. |
| BR-03 | Only a Company Administrator may invite or remove users from an organization.                                                                                                                                                   |
| BR-04 | Supplier-submitted data is held as “unverified” until approved by a Sustainability Manager or Carbon Auditor.                                                                                                                   |
| BR-05 | Emission factor matches below a configurable confidence threshold (default 80%) are automatically routed to manual review and cannot silently flow into a final report.                                                         |
| BR-06 | Once a report is submitted to a Government Auditor role, its underlying data becomes immutable (append-only correction log applies going forward).                                                                              |
| BR-07 | Cross-tenant data access is prohibited at the database and API layer under all circumstances, enforced independent of application-level RBAC.                                                                                   |

## 2.12 2.12 Future Enhancements

- Primary supplier-submitted LCA data ingestion for deeper Scope 3 categories.
- Carbon-credit / offset marketplace integration.
- On-premises / private-cloud deployment option for large enterprise customers.
- Expanded OCR language coverage (Spanish, Italian, Mandarin, Japanese).
- Predictive “what-if” scenario modeling for supplier switching and product re-design.
- Blockchain-anchored audit trail for immutable report provenance (under evaluation, not committed).

## 3. Functional Requirements

This chapter specifies functional requirements per module. Each requirement is uniquely identified (module prefix + number), assigned a priority (Must-Have / Should-Have / Could-Have per MoSCoW), and specified with actors, pre/postconditions, normal/alternative/exception flows, applicable business rules, validation rules, and acceptance criteria to support direct traceability into test cases (see §11.5, Requirement Traceability Matrix).

### 3.1 Module: Authentication & Authorization

#### 3.1.1 FR-AUTH-01 — User Registration and Organization Creation

- **Priority:** Must-Have
- **Description:** The system shall allow a new Company Administrator to register an account and create a new tenant organization.
- **Actors:** Company Administrator (prospective)
- **Preconditions:** The registering email address is not already associated with an existing account.
- **Postconditions:** A new tenant organization and an associated Company Administrator user record are created in a “Pending Verification” state.
- **Normal Flow:**
  1. User submits organization name, work email, password, and company registration details.
  2. System validates input and checks for existing accounts.
  3. System creates the organization and user records.
  4. System sends a verification email.
  5. User clicks the verification link; account is activated.
- **Alternative Flow:** A-1: User registers via Single Sign-On (Google Workspace / Microsoft Entra ID) — steps 1-2 replaced by OAuth handshake; email is pre-verified by the identity provider.
- **Exception Flow:** E-1: Email already registered → system returns error “Account already exists” and offers a login/reset link. E-2: Verification link expired (>24 hours) → system offers to resend.
- **Business Rules:** BR-03.
- **Validation Rules:** Password minimum 12 characters with mixed case, number, and symbol; work email domain must not be a public consumer domain (e.g., gmail.com) unless explicitly allow-listed for pilot/testing accounts.
- **Acceptance Criteria:**
  - AC-1: Given valid inputs, when the user submits registration, then an organization and admin user are created within 2 seconds and a verification email is sent within 30 seconds.
  - AC-2: Given a duplicate email, when registration is attempted, then the system rejects it with a clear error and does not create a duplicate record.

#### 3.1.2 FR-AUTH-02 — Login with Multi-Factor Authentication

- **Priority:** Must-Have

- **Description:** The system shall authenticate users via email/password or SSO, and shall enforce multi-factor authentication (MFA) for all roles with write access to financial or compliance data.
- **Actors:** All authenticated roles
- **Preconditions:** User account is active and verified.
- **Postconditions:** A valid JWT access token and refresh token are issued; a login audit event is recorded.
- **Normal Flow:** 1. User submits credentials. 2. System validates credentials. 3. System prompts for MFA code (TOTP or SMS). 4. User submits valid code. 5. System issues access/refresh tokens and redirects to the role-appropriate dashboard.
- **Alternative Flow:** A-1: Government Auditor and read-only roles may be exempted from MFA if organization policy allows (configurable).
- **Exception Flow:** E-1: Invalid credentials → generic “invalid email or password” error (no user enumeration). E-2: Account locked after 5 consecutive failed attempts within 15 minutes → 15-minute lockout with notification email. E-3: Invalid/expired MFA code → retry allowed up to 5 times before temporary lockout.
- **Business Rules:** BR-07 (tenant isolation enforced at token-scope level).
- **Validation Rules:** JWT access token TTL  $\leq$  15 minutes; refresh token TTL  $\leq$  7 days with rotation.
- **Acceptance Criteria:**
  - AC-1: Given valid credentials and a valid MFA code, the user is authenticated and receives tokens scoped to exactly one organization.
  - AC-2: Given 5 failed login attempts, the account is locked and an alert email is sent within 60 seconds.

### 3.1.3 FR-AUTH-03 — Role-Based Access Control (RBAC)

- **Priority:** Must-Have
- **Description:** The system shall enforce granular, role-based permissions on every API endpoint and UI action, per the role matrix in §2.7.
- **Actors:** All roles; enforced by the platform for every request.
- **Preconditions:** User is authenticated with a valid, non-expired token.
- **Postconditions:** Requests are permitted or denied strictly according to the role-permission matrix; denials are logged.
- **Normal Flow:** 1. Request arrives with bearer token. 2. Middleware resolves user, organization, and role. 3. Middleware checks the requested action against the permission matrix. 4. Request proceeds if authorized.
- **Exception Flow:** E-1: Insufficient permission → HTTP 403 with an audit log entry. E-2: Token references a deactivated user → HTTP 401 and forced logout.
- **Business Rules:** BR-03, BR-07.
- **Validation Rules:** Permission checks must occur server-side; client-side role checks are UX-only and never treated as authoritative.
- **Acceptance Criteria:** AC-1: A Procurement Team member attempting to submit a final report receives HTTP 403. AC-2: 100% of API endpoints have an associated automated authorization test.

## 3.2 3.2 Module: Organization Management

### 3.2.1 FR-ORG-01 — Organization Profile & Facility Configuration

- **Priority:** Must-Have
- **Description:** The system shall allow a Company Administrator to configure organization profile details, industry sector (for CBAM goods-category mapping), and one or more physical facilities.
- **Actors:** Company Administrator
- **Preconditions:** Organization exists.
- **Postconditions:** Facility records exist with address, country, and applicable CBAM goods category (if any).
- **Normal Flow:** 1. Admin navigates to Organization Settings. 2. Admin adds facility name, address, country, industry/CBAM category. 3. System geocodes and validates the address. 4. Facility is saved and available for document/supplier association.
- **Exception Flow:** E-1: Invalid/unrecognized address → system prompts for manual correction. E-2: CBAM category not applicable to organization's declared goods → system allows "non-CBAM" designation while still enabling GHG Protocol / ISO 14064 reporting.
- **Business Rules:** BR-01.
- **Validation Rules:** Country must be a valid ISO 3166-1 code; at least one facility required before document upload is enabled.
- **Acceptance Criteria:** AC-1: A saved facility appears in the facility selector when uploading documents within 1 second (cache-backed).

### 3.2.2 FR-ORG-02 — User Invitation and Role Assignment

- **Priority:** Must-Have
- **Description:** The system shall allow a Company Administrator to invite users by email and assign one or more roles.
- **Actors:** Company Administrator
- **Normal Flow:** 1. Admin enters invitee email and role(s). 2. System sends an invitation email with a time-limited signup link. 3. Invitee completes registration and is added to the organization with the assigned role(s).
- **Exception Flow:** E-1: Invitation link expired (>7 days) → admin may resend. E-2: Invitee already belongs to another organization with the same email → system requires a distinct email or SSO-linked multi-org account.
- **Business Rules:** BR-03.
- **Acceptance Criteria:** AC-1: An invited user who completes signup within the validity window is added with exactly the assigned role(s), no more, no less.

## 3.3 3.3 Module: Supplier Management

### 3.3.1 FR-SUP-01 — Supplier Master Data Management

- **Priority:** Must-Have
- **Description:** The system shall allow creation, editing, and bulk import (CSV/Excel) of supplier master records including name, tax ID, country,

category, and primary contact.

- **Actors:** Procurement Team, Company Administrator
- **Preconditions:** Organization exists.
- **Postconditions:** Supplier records are available for matching against extracted invoice/PO line items.
- **Normal Flow:** 1. User uploads a supplier CSV/Excel file or manually adds a supplier. 2. System validates required fields and de-duplicates against existing suppliers by tax ID/name-similarity. 3. System persists supplier records and indexes them for fuzzy matching.
- **Alternative Flow:** A-1: Bulk import with partial errors → system imports valid rows and returns a downloadable error report for invalid rows.
- **Exception Flow:** E-1: Duplicate supplier detected (fuzzy match  $\geq 90\%$  similarity) → system prompts to merge or create as distinct entity.
- **Business Rules:** BR-04.
- **Validation Rules:** Supplier name required; tax ID format validated per declared country where feasible.
- **Acceptance Criteria:** AC-1: Importing a 5,000-row supplier CSV completes with a success/error summary within 60 seconds. AC-2: Duplicate detection flags  $\geq 95\%$  of exact tax-ID duplicates.

### 3.3.2 FR-SUP-02 — Supplier Portal for Self-Submitted Data

- **Priority:** Should-Have
- **Description:** The system shall provide a restricted external portal allowing invited suppliers to submit product-level emissions data or confirm/correct auto-matched emission factors for goods they supply.
- **Actors:** Supplier, Sustainability Manager (approver)
- **Normal Flow:** 1. Sustainability Manager invites a supplier to the portal, scoped to specific product lines. 2. Supplier logs in via a restricted-scope token and submits data. 3. Submission enters “unverified” status. 4. Sustainability Manager or Auditor reviews and approves/rejects.
- **Business Rules:** BR-04.
- **Acceptance Criteria:** AC-1: Supplier-submitted data never becomes part of a final report without explicit internal approval.

### 3.3.3 FR-SUP-03 — Supplier Emissions Dashboard

- **Priority:** Should-Have
- **Description:** The system shall provide a per-supplier dashboard summarizing total attributed emissions, trend over time, and contribution to overall Scope 3 footprint.
- **Actors:** Sustainability Manager, Procurement Team, Carbon Auditor
- **Acceptance Criteria:** AC-1: Selecting a supplier renders their emissions trend chart and top contributing product categories within 2 seconds for organizations with up to 10,000 transactions/year. ## 3.4 Module: Document Upload

### 3.3.4 FR-DOC-01 — Multi-Format Document Upload

- **Priority:** Must-Have
- **Description:** The system shall allow authorized users to upload PDF, JPG/PNG, CSV, and XLSX documents (invoices, manifests, POs, ERP exports, utility bills) up to 50 MB per file, individually or as a bulk ZIP archive.
- **Actors:** Procurement Team, Finance Team, Logistics Team, Company Administrator
- **Preconditions:** User is authenticated and has upload permission for the target facility.
- **Postconditions:** File is stored in object storage, a document metadata record is created with status “Uploaded”, and the file is queued for processing.
- **Normal Flow:** 1. User selects a document type and target facility. 2. User drags/drops or selects files. 3. System virus-scans and validates file type/size. 4. System uploads to S3 and creates a document record. 5. System enqueues the document for OCR/extraction.
- **Alternative Flow:** A-1: Bulk ZIP upload → system extracts and processes each contained file individually, reporting per-file status.
- **Exception Flow:** E-1: File exceeds size limit → rejected with a clear error before upload begins. E-2: Virus/malware detected → file quarantined, upload rejected, security event logged. E-3: Unsupported file type → rejected with supported-format guidance.
- **Business Rules:** BR-01.
- **Validation Rules:** Accepted MIME types strictly allow-listed; filename sanitized; maximum 500 files per bulk batch.
- **Acceptance Criteria:** AC-1: A 10 MB PDF is fully uploaded and visible in “Processing” status within 5 seconds on a standard broadband connection. AC-2: 100% of files are scanned prior to persistence.

### 3.3.5 FR-DOC-02 — Document Status Tracking

- **Priority:** Must-Have
- **Description:** The system shall track and display each document’s lifecycle status: Uploaded → Processing → Extracted → Matched → Calculated → Reviewed (or Failed at any stage with reason).
- **Actors:** All internal roles
- **Acceptance Criteria:** AC-1: Status transitions are visible in the UI within 3 seconds of the underlying processing event via WebSocket/polling update.

## 3.4 3.5 Module: OCR Extraction

### 3.4.1 FR-OCR-01 — Optical Character Recognition Pipeline

- **Priority:** Must-Have
- **Description:** The system shall extract raw text and layout structure (tables, key-value regions) from scanned or image-based documents using an OCR engine prior to LLM-based structured extraction.
- **Actors:** System (automated)

- **Preconditions:** Document status is “Uploaded”.
- **Postconditions:** Raw OCR text and bounding-box layout metadata are persisted and linked to the source document.
- **Normal Flow:** 1. Worker pulls the document from the processing queue. 2. System detects whether the document is native-text PDF or image-based. 3. For image-based documents, OCR is applied per page. 4. Extracted text/layout is stored; status transitions to “Processing → Extracted” (pending AI extraction).
- **Exception Flow:** E-1: OCR confidence below threshold (e.g., poor scan quality) → document flagged “Needs Manual Review” and a notification is sent to the uploader.
- **Validation Rules:** Minimum acceptable average OCR confidence score: 70%; documents below this are still processed but flagged.
- **Acceptance Criteria:** AC-1: A single-page scanned invoice completes OCR within 8 seconds at p95. AC-2: OCR word-level accuracy  $\geq 98\%$  on clean 300dpi scans (benchmarked against a labeled test set).

### 3.5 3.6 Module: AI Data Extraction

#### 3.5.1 FR-AI-01 — Document Classification

- **Priority:** Must-Have
- **Description:** The system shall automatically classify each uploaded document into a type (Invoice, Shipping Manifest, Purchase Order, Utility Bill, ERP Export, Supplier List, Other) using an LLM-based classifier, overridable by the uploader.
- **Actors:** System (automated), Procurement/Finance/Logistics Team (override)
- **Acceptance Criteria:** AC-1: Document type classification accuracy  $\geq 96\%$  on the labeled validation set across all four launch languages.

#### 3.5.2 FR-AI-02 — Structured Line-Item Extraction

- **Priority:** Must-Have
- **Description:** The system shall extract structured line items (item/service description, quantity, unit of measure, unit price, total, currency, supplier reference, date) from classified documents using an LLM extraction pipeline with a defined JSON schema, grounded against the OCR layout.
- **Actors:** System (automated)
- **Preconditions:** Document is classified and OCR text is available.
- **Postconditions:** Structured line items are persisted with a link back to the exact source region (page/bounding box) of the document for auditability.
- **Normal Flow:** 1. System selects an extraction prompt/schema based on document type. 2. System invokes the configured LLM provider with OCR text/layout as grounding context. 3. System validates the LLM response against the JSON schema. 4. System persists validated line items with confidence scores. 5. Status transitions to “Extracted”.
- **Alternative Flow:** A-1: Primary LLM provider (OpenAI) unavailable or rate-limited → system fails over to secondary provider (Gemini) transparently.
- **Exception Flow:** E-1: LLM response fails schema validation after 2 retries → document flagged “Extraction Failed — Needs Manual Review”. E-2: Extrac-

tion confidence for a field below threshold → field is flagged inline for human confirmation without blocking the rest of the document.

- **Business Rules:** BR-01, BR-05.
- **Validation Rules:** All monetary values must resolve to a valid currency code; quantities must be non-negative numeric; every extracted line item must retain a traceable pointer to its source location in the original document.
- **Acceptance Criteria:** AC-1: Structured extraction achieves  $\geq 93\%$  field-level F1 score on the labeled benchmark set across invoice and PO document types. AC-2: 100% of persisted line items carry a source-document traceability pointer.

### 3.5.3 FR-AI-03 — Natural Language Query Assistant (Chat)

- **Priority:** Should-Have
- **Description:** The system shall provide a conversational assistant allowing users to ask natural-language questions about their emissions data (e.g., “Which supplier contributed the most Scope 3 emissions last quarter?”) and receive answers grounded in the organization’s own calculated data, with citations to underlying records.
- **Actors:** Sustainability Manager, Carbon Auditor, Company Administrator
- **Preconditions:** User is authenticated within their organization scope.
- **Postconditions:** Response is generated using retrieval-augmented generation constrained strictly to the requesting organization’s tenant data.
- **Exception Flow:** E-1: Query requests data outside the user’s role/tenant scope → assistant declines and explains the restriction, without leaking cross-tenant data.
- **Business Rules:** BR-07.
- **Acceptance Criteria:** AC-1: 100% of chat responses that reference numeric data include a citation to the underlying record(s). AC-2: Zero cross-tenant data leakage in adversarial red-team testing.

## 3.6 3.7 Module: Emission Factor Matching

### 3.6.1 FR-EF-01 — Semantic Emission Factor Matching

- **Priority:** Must-Have
- **Description:** The system shall match each extracted line item to the most appropriate emission factor record from the configured reference databases (DE-FRA, EPA, GHG Protocol) using vector embedding similarity search, returning a ranked list of candidates with confidence scores.
- **Actors:** System (automated)
- **Preconditions:** Line item extraction is complete.
- **Postconditions:** Each line item has an assigned emission factor (auto-accepted or pending review) with a recorded confidence score and the emission-factor database version used.
- **Normal Flow:** 1. System generates an embedding for the line-item description. 2. System performs a nearest-neighbor search against the vector database of emission factor descriptions. 3. Top candidate is auto-accepted if confidence  $\geq 80\%$  (configurable); otherwise routed to manual review. 4. Match is persisted

with factor ID, database version, and confidence.

- **Alternative Flow:** A-1: User manually searches and selects an emission factor, overriding the automatic match; override is logged with user identity and rationale.
- **Exception Flow:** E-1: No candidate exceeds a minimum viable similarity threshold (e.g., 40%) → line item flagged “Unmatched — Needs Manual Classification”.
- **Business Rules:** BR-01, BR-05.
- **Validation Rules:** Every accepted match must record the emission-factor database name and version/publication date used, for audit reproducibility.
- **Acceptance Criteria:** AC-1: Auto-match acceptance rate  $\geq 75\%$  of line items on a representative manufacturing dataset. AC-2: Of auto-accepted matches,  $\geq 95\%$  agree with expert auditor labeling in validation sampling.

### 3.6.2 FR-EF-02 — Emission Factor Database Management

- **Priority:** Must-Have
- **Description:** The system shall ingest, version, and allow Super Admin-controlled updates of emission factor reference datasets (DEFRA, EPA, GHG Protocol defaults) without disrupting historical calculation reproducibility.
- **Actors:** Super Admin
- **Postconditions:** New emission factor versions are available for future calculations; prior calculations remain bound to the factor version originally used.
- **Business Rules:** BR-01.
- **Acceptance Criteria:** AC-1: Re-running a historical report always reproduces the original result unless the user explicitly requests recalculation with updated factors.

## 3.7 3.8 Module: Carbon Footprint Calculation

### 3.7.1 FR-CALC-01 — Scope 1 Emissions Calculation

- **Priority:** Must-Have
- **Description:** The system shall calculate Scope 1 (direct) emissions from matched activity data such as owned-vehicle fuel consumption and on-site fuel combustion, applying the appropriate emission factor and unit conversion.
- **Actors:** System (automated)
- **Normal Flow:** 1. System aggregates matched fuel/combustion activity line items per facility per period. 2. System applies the matched emission factor(s) with correct unit conversion (e.g., liters → GJ → kg CO<sub>2</sub>e). 3. Result is persisted per facility/period with full calculation lineage.
- **Business Rules:** BR-01.
- **Validation Rules:** Unit conversions must use a single internal canonical unit system to avoid compounding rounding errors; all conversion factors are themselves versioned.
- **Acceptance Criteria:** AC-1: Calculated Scope 1 totals match manual auditor recalculation within 0.5% tolerance on the validation dataset.

### 3.7.2 FR-CALC-02 — Scope 2 Emissions Calculation

- **Priority:** Must-Have
- **Description:** The system shall calculate Scope 2 emissions from purchased electricity, steam, heating, and cooling using both location-based and market-based methods per the GHG Protocol Scope 2 Guidance.
- **Actors:** System (automated)
- **Normal Flow:** 1. System ingests utility bill line items (kWh, energy type, billing period, facility, country/grid region). 2. System applies grid-average emission factors (location-based) and supplier/contract-specific factors (market-based) where available. 3. Both results are persisted and both are made available in reporting.
- **Business Rules:** BR-01.
- **Acceptance Criteria:** AC-1: Both location-based and market-based Scope 2 totals are independently retrievable for the same reporting period.

### 3.7.3 FR-CALC-03 — Scope 3 Emissions Calculation

- **Priority:** Must-Have
- **Description:** The system shall calculate Scope 3 emissions using a spend-based and/or activity-based method for purchased goods and services (Category 1), upstream transportation (Category 4), and other applicable categories, based on matched line items and logistics data.
- **Actors:** System (automated)
- **Normal Flow:** 1. System aggregates matched purchased-goods and transportation line items. 2. System applies category-appropriate emission factors (spend-based \$/CO<sub>2</sub>e or activity-based unit/CO<sub>2</sub>e, preferring activity-based where quantity/weight/distance data is available). 3. Results are persisted per supplier, product category, and Scope 3 category.
- **Business Rules:** BR-01, BR-05.
- **Acceptance Criteria:** AC-1: The system correctly prioritizes activity-based over spend-based calculation whenever sufficient activity data (weight, distance, mode) is present in the source document. AC-2: Calculated Scope 3 Category 4 transport emissions vary appropriately by declared transport mode (road/rail/sea/air) using mode-specific factors.

### 3.7.4 FR-CALC-04 — CBAM-Specific Embedded Emissions Calculation

- **Priority:** Must-Have
- **Description:** For goods within CBAM-covered categories (iron & steel, aluminum, cement, fertilizers, hydrogen, electricity), the system shall calculate embedded direct and indirect specific emissions per tonne of product in the format required by the CBAM declaration.
- **Actors:** System (automated), Sustainability Manager (review)
- **Business Rules:** CN-03, BR-01.
- **Acceptance Criteria:** AC-1: Output fields map 1:1 to the current CBAM quarterly declaration schema field list. AC-2: A change to the underlying CBAM

schema (per CN-03) can be applied via configuration without a core calculation-engine code change. ## 3.9 Module: Analytics Dashboard

### 3.7.5 FR-ANLT-01 — Organization Emissions Dashboard

- **Priority:** Must-Have
- **Description:** The system shall provide a role-appropriate dashboard summarizing total Scope 1/2/3 emissions, trend over time, breakdown by facility/supplier/product category, and comparison to the prior reporting period.
- **Actors:** Sustainability Manager, Company Administrator, Carbon Auditor
- **Acceptance Criteria:** AC-1: Dashboard initial render completes within 2 seconds (p95) for organizations with up to 100,000 transactions/year, using pre-aggregated materialized views.

### 3.7.6 FR-ANLT-02 — Carbon Hotspot Detection

- **Priority:** Must-Have
- **Description:** The system shall automatically identify suppliers, product categories, and logistics lanes contributing a disproportionate share of total emissions using a combination of Pareto (80/20) analysis and statistical outlier detection, and surface them as ranked “hotspots” with contextual explanation.
- **Actors:** System (automated), Sustainability Manager
- **Normal Flow:** 1. System recomputes hotspot rankings on each new calculation batch (or nightly, whichever is more frequent). 2. System applies outlier detection (e.g., IQR or isolation forest) against peer suppliers/categories. 3. Ranked hotspots with a plain-language explanation are surfaced on the dashboard.
- **Acceptance Criteria:** AC-1: Hotspot list updates within 15 minutes of a new calculation batch completing. AC-2: Each hotspot entry includes at least one human-readable explanatory factor (e.g., “42% above category average per unit”).

### 3.7.7 FR-ANLT-03 — Emission Trend Forecasting

- **Priority:** Should-Have
- **Description:** The system shall forecast projected emissions for the next 1-4 reporting quarters based on historical trend, using a time-series model, and display a confidence interval.
- **Actors:** Sustainability Manager
- **Acceptance Criteria:** AC-1: Forecast is regenerated automatically whenever a new quarter of actuals is finalized. AC-2: Forecast displays an explicit confidence interval, not a single point estimate.

## 3.8 3.10 Module: AI Recommendations

### 3.8.1 FR-REC-01 — Emission Reduction Recommendation Engine

- **Priority:** Should-Have

- **Description:** The system shall generate ranked, actionable recommendations for reducing emissions (e.g., “switch supplier X to lower-carbon supplier Y for category Z, estimated reduction: N tCO2e/year”) based on detected hotspots and comparable lower-emission alternatives within the customer’s own supplier base or category benchmarks.
- **Actors:** System (automated), Sustainability Manager
- **Exception Flow:** E-1: Insufficient data to estimate a reliable alternative → recommendation is withheld rather than shown with low-confidence numbers.
- **Acceptance Criteria:** AC-1: Every recommendation includes an estimated emissions-reduction figure and its underlying assumption set, viewable on demand. AC-2: No recommendation is shown with an unstated confidence/assumption basis.

### 3.9 3.11 Module: Reporting (CBAM / GHG Protocol)

#### 3.9.1 FR-RPT-01 — GHG Protocol Corporate Report Generation

- **Priority:** Must-Have
- **Description:** The system shall generate a downloadable GHG Protocol-aligned corporate emissions report (PDF and XLSX) for a selected organization, facility set, and reporting period, including Scope 1, Scope 2 (location- and market-based), and available Scope 3 categories.
- **Actors:** Sustainability Manager, Carbon Auditor
- **Preconditions:** All in-scope documents for the period have status “Calculated” or “Reviewed”; no unresolved anomalies remain per BR-02.
- **Postconditions:** A versioned, immutable report artifact is stored and available for download; a generation event is recorded in the audit log.
- **Normal Flow:** 1. User selects org scope and reporting period. 2. System validates BR-02 (no unresolved anomalies). 3. System compiles calculated data into the report template. 4. System renders PDF/XLSX and stores the artifact with a version identifier. 5. User downloads or shares the report.
- **Exception Flow:** E-1: Unresolved anomalies exist → generation is blocked with a list of blocking items and a link to resolve them.
- **Business Rules:** BR-02, BR-06.
- **Acceptance Criteria:** AC-1: Generated PDF report renders correctly across major PDF viewers and includes a data-lineage appendix listing source documents per figure.

#### 3.9.2 FR-RPT-02 — CBAM Quarterly/Annual Declaration Report

- **Priority:** Must-Have
- **Description:** The system shall generate a CBAM declaration-ready report matching the current official schema for covered goods categories, including embedded direct/indirect emissions per tonne and total imported quantity per CN code.
- **Actors:** Sustainability Manager, Carbon Auditor
- **Business Rules:** CN-03, BR-02, BR-06.

- **Acceptance Criteria:** AC-1: Field-for-field schema validation against the current published CBAM declaration template passes with zero missing required fields for in-scope goods.

### 3.9.3 FR-RPT-03 — Report Submission and Immutability Lock

- **Priority:** Must-Have
- **Description:** Once a Sustainability Manager or Carbon Auditor marks a report “Submitted,” the system shall lock the underlying data snapshot as immutable and record any subsequent corrections as a linked, versioned addendum rather than an in-place edit.
- **Actors:** Sustainability Manager, Carbon Auditor
- **Business Rules:** BR-06.
- **Acceptance Criteria:** AC-1: Attempting to edit a locked report’s source calculation returns an error directing the user to the correction/addendum workflow. AC-2: 100% of post-submission corrections are visible in the audit trail with before/after values.

## 3.10 3.12 Module: Notification System

### 3.10.1 FR-NOTIF-01 — Event-Driven Notifications

- **Priority:** Must-Have
- **Description:** The system shall send in-app and email notifications for key events: document processing failure, anomaly flagged, report ready for review, report submitted, user invited, MFA/security events.
- **Actors:** All roles (recipient-dependent on event type)
- **Acceptance Criteria:** AC-1: Notifications are delivered (queued for send) within 60 seconds of the triggering event. AC-2: Users can configure per-category notification preferences (in-app only / email / both).

## 3.11 3.13 Module: Audit Logs

### 3.11.1 FR-AUD-01 — Immutable Audit Trail

- **Priority:** Must-Have
- **Description:** The system shall maintain an append-only audit log capturing actor, timestamp, action, affected entity, and before/after state for all create/update/delete operations on organizational, supplier, document, calculation, and report data.
- **Actors:** System (automated); viewable by Company Administrator, Carbon Auditor, Super Admin
- **Business Rules:** BR-06, BR-07.
- **Validation Rules:** Audit records themselves cannot be edited or deleted through any application interface, including by Super Admin.
- **Acceptance Criteria:** AC-1: 100% of state-changing API calls produce a corresponding audit record. AC-2: Audit log query by entity returns full history within 3 seconds for entities with up to 10,000 historical events.

### 3.12 3.14 Module: Administration

#### 3.12.1 FR-ADM-01 — Super Admin Cross-Tenant Operations Console

- **Priority:** Must-Have
- **Description:** The system shall provide a Super Admin console for platform-level operations: tenant provisioning/suspension, emission-factor database version management, system health monitoring, and impersonation-for-support with mandatory audit logging and customer consent flag.
- **Actors:** Super Admin
- **Business Rules:** BR-07.
- **Validation Rules:** Support impersonation sessions are time-boxed (default 60 minutes), fully audit-logged, and require an active support ticket reference.
- **Acceptance Criteria:** AC-1: Every impersonation session produces an audit record visible to the impersonated organization's Company Administrator.

### 3.13 3.15 Module: Settings & User Profile

#### 3.13.1 FR-SET-01 — User Profile and Preferences

- **Priority:** Should-Have
- **Description:** The system shall allow users to manage their profile (name, contact info, MFA device), language/locale, and notification preferences.
- **Actors:** All authenticated roles
- **Acceptance Criteria:** AC-1: Profile changes are persisted and reflected across active sessions within 5 seconds.

#### 3.13.2 FR-SET-02 — Organization Integration Settings

- **Priority:** Must-Have
- **Description:** The system shall allow a Company Administrator to configure ERP integrations (SAP, Oracle ERP Cloud, Microsoft Dynamics 365), API keys, and default emission-calculation preferences (e.g., market-based vs. location-based Scope 2 default).
- **Actors:** Company Administrator
- **Acceptance Criteria:** AC-1: API keys are stored encrypted at rest and are never displayed in plaintext after initial creation. ## 3.16 User Stories

| ID    | As a...                | I want to...                                                    | So that...                                      | Linked Requirement(s) |
|-------|------------------------|-----------------------------------------------------------------|-------------------------------------------------|-----------------------|
| US-01 | Sustainability Manager | upload a batch of invoices and shipping manifests in one action | I don't have to process documents one at a time | FR-DOC-01             |

| ID    | As a...                 | I want to...                                                                | So that...                                                                | Linked Requirement(s) |
|-------|-------------------------|-----------------------------------------------------------------------------|---------------------------------------------------------------------------|-----------------------|
| US-02 | Sustainability Manager  | see which suppliers contribute the most to my Scope 3 footprint             | I can prioritize where to focus reduction efforts                         | FR-ANLT-02            |
| US-03 | Carbon Auditor          | trace every number in a report back to its source                           | I can defend the report under regulatory scrutiny                         | FR-AI-02, FR-EF-01    |
| US-04 | Procurement Team member | upload purchase orders without understanding carbon accounting              | my documents still contribute correctly to the emissions calculation      | FR-DOC-01, FR-AI-02   |
| US-05 | Company Administrator   | invite my finance and logistics colleagues with scoped permissions          | each person only sees and does what's relevant to their job               | FR-ORG-02, FR-AUTH-03 |
| US-06 | Sustainability Manager  | generate a CBAM-compliant report in one click                               | I avoid paying a consultant \$50K+ to compile it manually                 | FR-RPT-02             |
| US-07 | Government Auditor      | view a submitted report and confirm it hasn't been altered since submission | I can trust the declaration for regulatory purposes                       | FR-RPT-03, FR-AUD-01  |
| US-08 | Supplier                | submit our product-specific emissions data directly                         | our customer's report reflects our real footprint, not a generic estimate | FR-SUP-02             |

| ID    | As a...                | I want to...                                                                          | So that...                                                                | Linked Requirement(s) |
|-------|------------------------|---------------------------------------------------------------------------------------|---------------------------------------------------------------------------|-----------------------|
| US-09 | Sustainability Manager | ask “which supplier had the biggest emissions increase this quarter” in plain English | I don’t have to build a custom report or filter manually                  | FR-AI-03              |
| US-10 | Finance Team member    | upload utility bills and see the resulting Scope 2 calculation immediately            | I can verify the numbers match our energy invoices                        | FR-CALC-02            |
| US-11 | Super Admin            | update the DEFRA emission factor database without breaking historical reports         | past reports stay reproducible while new calculations use current factors | FR-EF-02              |
| US-12 | Sustainability Manager | receive a recommendation on which supplier switch would cut the most emissions        | I can make a data-driven case to procurement leadership                   | FR-REC-01             |

### 3.14 3.17 Representative Use Cases

#### 3.14.1 UC-01: Generate a Quarterly CBAM Declaration

- **Actors:** Sustainability Manager (primary), Carbon Auditor (secondary)
- **Trigger:** End of a CBAM reporting quarter.
- **Preconditions:** All in-scope documents for the quarter have completed extraction, matching, and calculation.
- **Main Success Scenario:**
  1. Sustainability Manager selects “New CBAM Report,” the reporting quarter, and the CN-code-covered goods scope.
  2. System validates there are no unresolved anomalies for the period (BR-02).
  3. System compiles embedded direct/indirect emissions per CN code from the calculation engine.
  4. System renders the report against the current CBAM schema and displays

a preview.

5. Sustainability Manager reviews and requests Carbon Auditor sign-off.

6. Carbon Auditor reviews line-level traceability and approves.

7. Sustainability Manager submits; system locks the data snapshot (BR-06).

- **Extensions:** 2a. Unresolved anomalies exist → system blocks generation and lists items to resolve (returns to document review workflow). 6a. Auditor rejects → report returns to draft with reviewer comments attached.
- **Postconditions:** A locked, versioned CBAM report artifact exists and is available for download/submission to authorities.

### 3.14.2 UC-02: Onboard a New Manufacturing Facility

- **Actors:** Company Administrator
- **Main Success Scenario:** 1. Admin adds a new facility with address and CBAM category. 2. Admin uploads or links the facility's supplier list. 3. Admin invites Procurement, Finance, and Logistics users scoped to the facility. 4. Facility becomes available in document upload and reporting scope selectors.
- **Postconditions:** The facility is fully operational for document ingestion and reporting.

### 3.14.3 UC-03: Resolve a Flagged Emission Anomaly

- **Actors:** Sustainability Manager, Carbon Auditor
- **Trigger:** Anomaly detection flags a line item (e.g., emission factor confidence below threshold, or a statistical outlier vs. peer suppliers).
- **Main Success Scenario:** 1. Sustainability Manager opens the flagged item from the review queue. 2. System displays the source document region, candidate emission factor matches, and the reason for flagging. 3. Manager selects the correct factor or confirms the outlier with a documented rationale. 4. System recalculates the affected figures and clears the flag.
- **Extensions:** 3a. Manager cannot resolve confidently → escalates to Carbon Auditor for final determination.
- **Postconditions:** The item is no longer blocking report generation (BR-02).

3.15 3.18 Sample End-to-End Workflow (Illustrative)

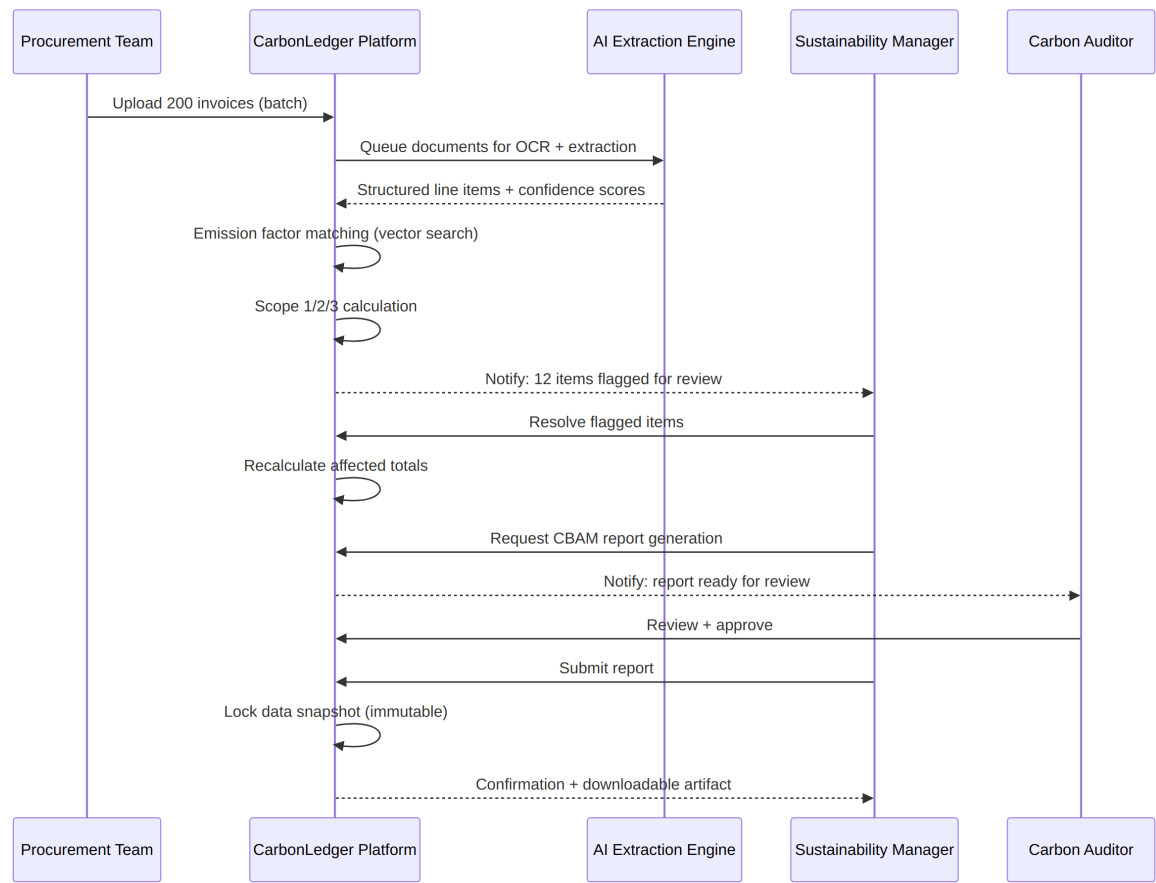


Figure 3.1 — Illustrative End-to-End Sequence: Invoice Upload to Submitted CBAM Report

## 4. External Interface Requirements

### 4.1 User Interface Requirements

- UI-01: The web application shall be responsive and support desktop ( $\geq 1280\text{px}$ ) and tablet ( $\geq 768\text{px}$ ) viewports; mobile phone support is limited to notification review and report download in v1.0.
- UI-02: All data-entry forms shall provide inline validation with field-level error messages, not just form-level errors.
- UI-03: The dashboard shall meet WCAG 2.1 AA accessibility standards, including keyboard navigation and screen-reader label coverage.
- UI-04: Long-running operations (document batch processing, report generation) shall display real-time progress indicators via WebSocket updates, not require manual page refresh.
- UI-05: All monetary and emissions figures shall display their unit of measure and, on hover, their calculation lineage (source documents + emission factor version).

### 4.2 REST API Specifications

All APIs are versioned under `/api/v1/`, secured via OAuth 2.1 bearer tokens (JWT), and scoped to the authenticated user's organization. Responses use application/json. Pagination uses limit/offset query parameters with a maximum limit of 200.

#### 4.2.1 Authentication API

| Method | Endpoint                               | Description                                                   | Auth Required   |
|--------|----------------------------------------|---------------------------------------------------------------|-----------------|
| POST   | <code>/api/v1/auth/register</code>     | Register a new organization and admin user                    | No              |
| POST   | <code>/api/v1/auth/login</code>        | Authenticate with email/password, returns MFA challenge token | No              |
| POST   | <code>/api/v1/auth/mfa/verify</code>   | Verify MFA code, returns access/refresh tokens                | Challenge token |
| POST   | <code>/api/v1/auth/refresh</code>      | Exchange refresh token for new access token                   | Refresh token   |
| POST   | <code>/api/v1/auth/logout</code>       | Revoke current refresh token                                  | Yes             |
| POST   | <code>/api/v1/auth/sso/callback</code> | OAuth SSO callback handler                                    | No              |

**4.2.2 4.2.2 Document API**

| Method | Endpoint                         | Description                                                      | Auth Required |
|--------|----------------------------------|------------------------------------------------------------------|---------------|
| POST   | /api/v1/documents                | Upload a document (multipart) or initiate a presigned S3 upload  | Yes           |
| GET    | /api/v1/documents                | List documents with filters (status, type, facility, date range) | Yes           |
| GET    | /api/v1/documents/{id}           | Get document metadata, status, and extraction results            | Yes           |
| GET    | /api/v1/documents/{id}/download  | Download original source file                                    | Yes           |
| DELETE | /api/v1/documents/{id}           | Soft-delete a document (retains audit trail)                     | Yes (Admin)   |
| POST   | /api/v1/documents/{id}/retrigger | Re-trigger OCR/extraction pipeline                               | Yes           |

**4.2.3 4.2.3 Supplier API**

| Method | Endpoint                         | Description                                    | Auth Required |
|--------|----------------------------------|------------------------------------------------|---------------|
| GET    | /api/v1/suppliers                | List suppliers with search/filter              | Yes           |
| POST   | /api/v1/suppliers                | Create a supplier                              | Yes           |
| POST   | /api/v1/suppliers/import         | Bulk import via CSV/XLSX                       | Yes           |
| GET    | /api/v1/suppliers/{id}           | Get supplier detail and emissions summary      | Yes           |
| PATCH  | /api/v1/suppliers/{id}           | Update supplier fields                         | Yes           |
| GET    | /api/v1/suppliers/{id}/emissions | Retrieve emissions attributed to this supplier | Yes           |

**4.2.4 4.2.4 Emission API**

| Method | Endpoint                                          | Description                                      | Auth Required |
|--------|---------------------------------------------------|--------------------------------------------------|---------------|
| GET    | /api/v1/emissions/summary                         | Aggregated Scope 1/2/3 totals for a scope/period | Yes           |
| GET    | /api/v1/emissions/line-items                      | Line-item level calculation detail with lineage  | Yes           |
| POST   | /api/v1/emissions/line-items/{id}/override-factor | Manually override an emission factor match       | Yes           |
| GET    | /api/v1/emissions/hotspots                        | Spotted hotspot list                             | Yes           |
| GET    | /api/v1/emissions/recommendations                 | AI-generated reduction recommendations           | Yes           |
| GET    | /api/v1/emissions/forecast                        | Forecasted emissions with confidence interval    | Yes           |

#### 4.2.5 Reporting API

| Method | Endpoint                      | Description                                 | Auth Required |
|--------|-------------------------------|---------------------------------------------|---------------|
| POST   | /api/v1/reports               | Generate a new report (GHG Protocol / CBAM) | Yes           |
| GET    | /api/v1/reports               | List reports with status                    | Yes           |
| GET    | /api/v1/reports/{id}          | Get report metadata and download links      | Yes           |
| POST   | /api/v1/reports/{id}/submit   | Submit and lock a report                    | Yes           |
| POST   | /api/v1/reports/{id}/addendum | Submit a post-lock correction addendum      | Yes           |

#### 4.2.6 Common Error Response Format

```
{
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "Field 'quantity' must be a non-negative number",
    "field": "quantity",
    "request_id": "req_8f2a1c9d"
  }
}
```

**4.2.7 4.2.7 HTTP Status Codes Used**

| Code | Meaning               | Typical Usage                                                            |
|------|-----------------------|--------------------------------------------------------------------------|
| 200  | OK                    | Successful GET/PATCH                                                     |
| 201  | Created               | Successful POST creating a resource                                      |
| 202  | Accepted              | Async operation queued (e.g., document processing)                       |
| 400  | Bad Request           | Schema/validation failure                                                |
| 401  | Unauthorized          | Missing/invalid/expired token                                            |
| 403  | Forbidden             | Authenticated but not authorized (RBAC denial)                           |
| 404  | Not Found             | Resource does not exist or is outside tenant scope                       |
| 409  | Conflict              | Duplicate resource / immutable-record edit attempt                       |
| 422  | Unprocessable Entity  | Well-formed but semantically invalid request                             |
| 429  | Too Many Requests     | Rate limit exceeded                                                      |
| 500  | Internal Server Error | Unhandled server-side fault                                              |
| 503  | Service Unavailable   | Dependent service (e.g., LLM provider) unavailable, failover in progress |

**4.2.8 4.2.8 Application Error Codes (excerpt)**

| Code                        | Description                                                 |
|-----------------------------|-------------------------------------------------------------|
| VALIDATION_ERROR            | Request payload failed schema validation                    |
| DUPLICATE_RESOURCE          | Resource conflicts with an existing unique record           |
| TENANT_SCOPE_VIOLATION      | Requested resource does not belong to caller's organization |
| DOCUMENT_UNSUPPORTED_FORMAT | Uploaded file type is not supported                         |
| EXTRACTION_FAILED           | AI extraction pipeline failed after retries                 |
| ANOMALY_UNRESOLVED          | Report generation blocked by unresolved anomalies (BR-02)   |
| REPORT_LOCKED               | Attempt to modify a submitted/locked report                 |

| Code                                 | Description                                                                                           |
|--------------------------------------|-------------------------------------------------------------------------------------------------------|
| RATE_LIMITED<br>PROVIDER_UNAVAILABLE | Caller exceeded allotted request rate<br>Upstream LLM/OCR provider<br>unavailable, failover attempted |

### 4.3 4.3 Communication Interfaces

- The system communicates exclusively over HTTPS/TLS 1.2+ for all client-server and service-to-service traffic outside the private VPC.
- Asynchronous processing (document extraction, report generation) uses an internal message queue (Redis-backed); no external communication protocol is exposed for this.
- Outbound webhooks (Should-Have, v1.1) will use HTTPS POST with HMAC-SHA256 payload signing.

### 4.4 4.4 Hardware Requirements

CarbonLedger is a cloud-hosted SaaS product; the customer requires no specific on-premises hardware beyond a device capable of running a modern web browser with a broadband internet connection (minimum 5 Mbps recommended for bulk document upload).

### 4.5 4.5 Software Interfaces

| Interface                | Purpose                                               | Protocol            |
|--------------------------|-------------------------------------------------------|---------------------|
| OpenAI API               | Primary LLM for document extraction, chat assistant   | HTTPS/REST          |
| Google Gemini API        | Secondary/failover LLM provider                       | HTTPS/REST          |
| AWS S3                   | Document and report artifact storage                  | HTTPS/REST (S3 API) |
| PostgreSQL               | Primary relational data store                         | TCP/TLS (libpq)     |
| Redis                    | Cache and job queue                                   | TCP/TLS             |
| ChromaDB                 | Vector similarity search for emission factor matching | HTTP/gRPC           |
| SendGrid (or equivalent) | Transactional email delivery                          | HTTPS/REST          |

### 4.6 4.6 Third-Party ERP Integrations

| System                 | Integration Method                                  | Data Exchanged                                                |
|------------------------|-----------------------------------------------------|---------------------------------------------------------------|
| SAP (S/4HANA)          | OData/REST connector,<br>scheduled batch pull       | Purchase orders, invoices,<br>material master                 |
| Oracle ERP Cloud       | REST API (Oracle<br>Integration Cloud)              | Purchase orders, supplier<br>master, invoices                 |
| Microsoft Dynamics 365 | Dataverse Web API                                   | Purchase orders, vendor<br>records, invoices                  |
| Generic ERP            | CSV/XLSX scheduled<br>SFTP drop or manual<br>upload | Any of the above, mapped<br>via configurable field<br>mapping |

## 5. Non-Functional Requirements

### 5.1 Performance

| ID          | Requirement                                       | Target                                                       |
|-------------|---------------------------------------------------|--------------------------------------------------------------|
| NFR-PERF-01 | Dashboard initial load time                       | $\leq 2s$ p95 for orgs with $\leq 100,000$ transactions/year |
| NFR-PERF-02 | Document upload acknowledgment                    | $\leq 5s$ for files up to 10MB                               |
| NFR-PERF-03 | Single-document OCR + extraction pipeline latency | $\leq 30s$ p95 end-to-end                                    |
| NFR-PERF-04 | Bulk batch processing throughput                  | $\geq 500$ documents/hour per tenant worker pool             |
| NFR-PERF-05 | REST API response time (non-AI endpoints)         | $\leq 300ms$ p95                                             |
| NFR-PERF-06 | Report generation (standard scope)                | $\leq 60s$ p95                                               |

### 5.2 Scalability

- NFR-SCALE-01: The platform shall support horizontal auto-scaling of stateless API and worker pods based on CPU/queue-depth metrics via Kubernetes Horizontal Pod Autoscaler.
- NFR-SCALE-02: The system shall support at least 500 concurrent tenant organizations and 50,000 documents processed per day at launch scale, architected to scale to 5,000 tenants without a re-architecture.
- NFR-SCALE-03: The database layer shall support read-replica scaling for analytics/reporting query load separate from transactional write load.

### 5.3 Availability

- NFR-AVAIL-01: The platform shall target 99.9% monthly uptime ( $\approx 43$  minutes downtime/month) for core application services, excluding scheduled maintenance windows communicated  $\geq 72$  hours in advance.
- NFR-AVAIL-02: The system shall be deployed across a minimum of two Availability Zones within the primary AWS region.

### 5.4 Reliability

- NFR-REL-01: Document processing jobs shall be idempotent and safely retryable; a failed job shall not produce duplicate line items or double-counted emissions.
- NFR-REL-02: Mean Time Between Failures (MTBF) for core services shall exceed 720 hours; Mean Time To Recovery (MTTR) shall not exceed 30 minutes for P1 incidents.

- NFR-REL-03: The system shall implement circuit breakers and automatic failover between primary and secondary LLM providers.

## 5.5 5.5 Usability

- NFR-USE-01: A new Sustainability Manager shall be able to complete first document upload through first draft report without external training, validated via unmoderated usability testing with a System Usability Scale (SUS) score  $\geq 75$ .
- NFR-USE-02: Error messages shall be actionable, stating what went wrong and the recommended next step.

## 5.6 5.6 Accessibility

- NFR-ACC-01: The web application shall conform to WCAG 2.1 Level AA.
- NFR-ACC-02: All interactive elements shall be operable via keyboard alone.

## 5.7 5.7 Maintainability

- NFR-MAINT-01: Backend services shall maintain  $\geq 80\%$  automated test coverage on business-logic modules (calculation engine, matching engine).
- NFR-MAINT-02: All services shall expose structured (JSON) logs correlated by a request ID propagated across service boundaries.
- NFR-MAINT-03: Infrastructure shall be defined as code (Terraform/Kubernetes manifests) with no manual production configuration changes permitted outside emergency break-glass procedures.

## 5.8 5.8 Portability

- NFR-PORT-01: The application shall be fully containerized (Docker) with no host-specific dependencies, enabling deployment to any conformant Kubernetes cluster.
- NFR-PORT-02: Object storage access shall use the S3 API surface, enabling substitution of S3-compatible providers without application code changes.

## 5.9 5.9 Security

(Full detail in Chapter 8.) Summary requirements:

- NFR-SEC-01: All data in transit encrypted via TLS 1.2+; all data at rest encrypted via AES-256.
- NFR-SEC-02: Role-based access control enforced server-side on every endpoint.
- NFR-SEC-03: Annual third-party penetration testing and continuous automated dependency vulnerability scanning.

## 5.10 5.10 Compliance

- NFR-COMP-01: The platform shall support GDPR data-subject rights workflows (access, rectification, erasure, portability) for any personal data processed (pri-

marily user account data, not the business/supplier data itself).

- NFR-COMP-02: The platform shall maintain SOC 2 Type II readiness within 18 months of general availability.
- NFR-COMP-03: EU-tenant data shall be stored and processed within an EU AWS region when the customer selects EU data residency.

### 5.11 5.11 Backup

- NFR-BKUP-01: PostgreSQL shall be backed up via continuous WAL archiving plus daily full snapshots, retained 35 days.
- NFR-BKUP-02: Object storage (S3) shall use versioning and cross-region replication for disaster recovery.

### 5.12 5.12 Recovery

- NFR-REC-01: Recovery Point Objective (RPO):  $\leq 15$  minutes. Recovery Time Objective (RTO):  $\leq 4$  hours for full regional failover.
- NFR-REC-02: Disaster recovery procedures shall be tested at least semi-annually via a documented tabletop or live failover exercise.

### 5.13 5.13 Logging

- NFR-LOG-01: All application, security, and audit logs shall be centrally aggregated with a minimum retention of 400 days for security logs and 7 years for audit logs (to satisfy typical regulatory retention expectations for compliance data).
- NFR-LOG-02: Logs shall never contain plaintext secrets, passwords, or full document contents; PII shall be masked in application logs.

### 5.14 5.14 Monitoring

- NFR-MON-01: The platform shall expose health-check and readiness endpoints for all services, monitored by Kubernetes liveness/readiness probes.
- NFR-MON-02: Key business metrics (documents processed, extraction accuracy, match confidence distribution, calculation throughput) shall be tracked on operational dashboards with alerting thresholds.
- NFR-MON-03: On-call alerting shall page within 5 minutes of a P1 service-impacting condition.

### 5.15 5.15 Non-Functional Requirements Summary Table

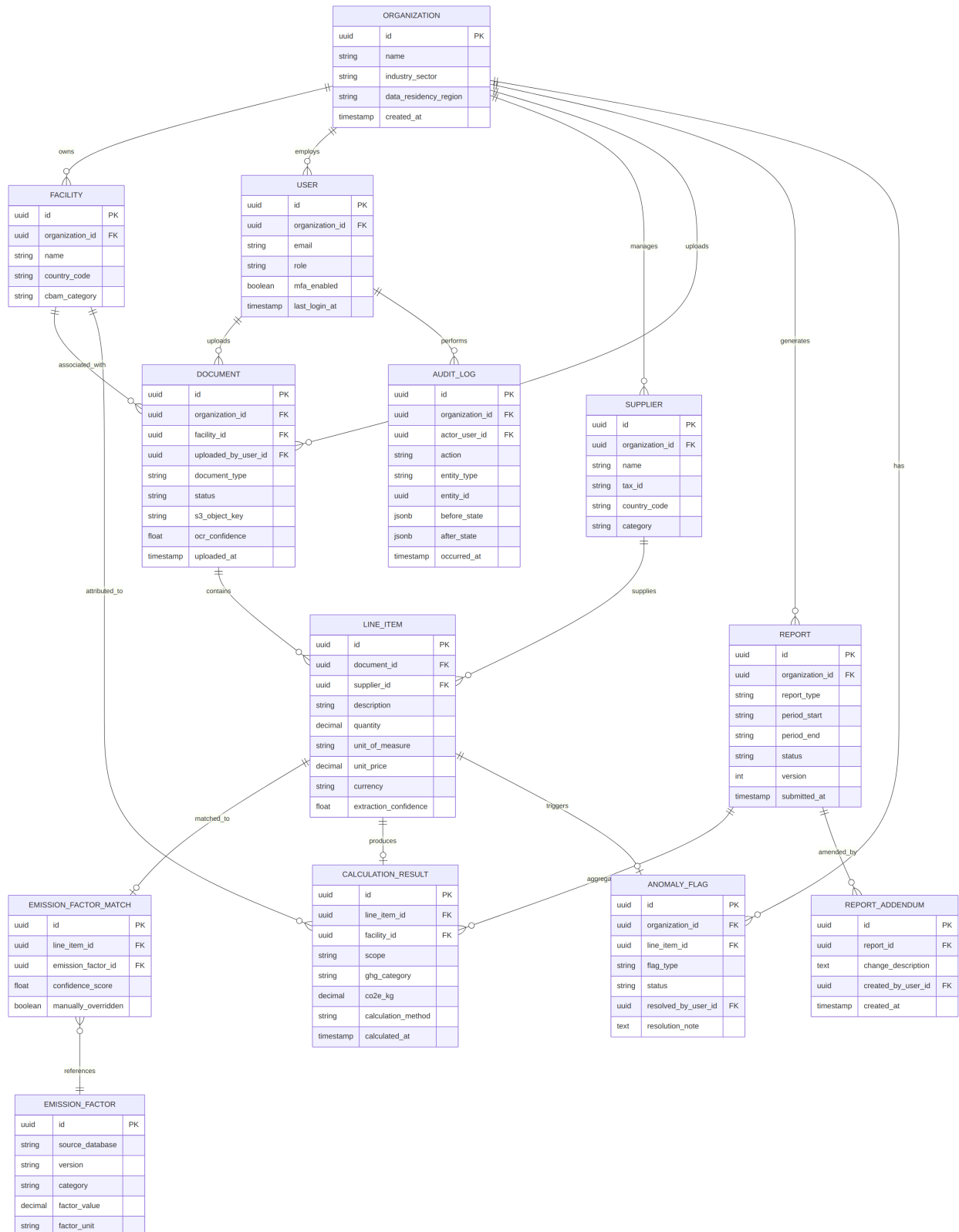
| Category     | Key Metric                   | Target              |
|--------------|------------------------------|---------------------|
| Performance  | API p95 latency              | $\leq 300\text{ms}$ |
| Scalability  | Concurrent tenants at launch | 500                 |
| Availability | Monthly uptime               | 99.9%               |
| Reliability  | MTTR (P1)                    | $\leq 30$ min       |

| Category   | Key Metric                           | Target             |
|------------|--------------------------------------|--------------------|
| Recovery   | RPO / RTO                            | 15 min / 4 hr      |
| Security   | Data at rest / in transit encryption | AES-256 / TLS 1.2+ |
| Compliance | Audit log retention                  | 7 years            |



## 6. Data Requirements

### 6.1 Entity Relationship Diagram



**Figure 6.1 — Entity Relationship Diagram****6.2 Database Tables — Structural Summary**

| Table                 | Purpose                                         | Primary Key | Notable Foreign Keys                               |
|-----------------------|-------------------------------------------------|-------------|----------------------------------------------------|
| organization          | Tenant record                                   | id          | —                                                  |
| user                  | Platform user account                           | id          | organization_id                                    |
| facility              | Physical site belonging to an org               | id          | organization_id                                    |
| supplier              | Supplier master record                          | id          | organization_id                                    |
| document              | Uploaded source file + processing status        | id          | organization_id, facility_id, uploaded_by_user_id  |
| line_item             | Extracted structured line from a document       | id          | document_id, supplier_id                           |
| emission_factor       | Reference emission factor record                | id          | —                                                  |
| emission_factor_match | Link between a line item and its matched factor | id          | line_item_id, emission_factor_id                   |
| calculation_result    | Calculated CO2e value for a line item           | id          | line_item_id, facility_id                          |
| anomaly_flag          | Flagged item requiring review                   | id          | organization_id, line_item_id, resolved_by_user_id |
| report                | Generated compliance report                     | id          | organization_id                                    |
| report_addendum       | Post-lock correction record                     | id          | report_id, created_by_user_id                      |
| audit_log             | Immutable audit trail                           | id          | organization_id, actor_user_id                     |

**6.3 Normalization**

The schema is normalized to Third Normal Form (3NF) for transactional tables (organization, user, facility, supplier, document, line\_item) to eliminate update anomalies. calculation\_result is intentionally denormalized with respect to scope/ghg\_category labels for reporting query performance, refreshed via a materialized aggregation layer rather than joined at query time. audit\_log.before\_state/after\_state use JSONB to accommodate heterogeneous entity schemas without a proliferation of per-entity audit tables.

## 6.4 6.4 Data Validation Rules

| Field                              | Rule                                                              |
|------------------------------------|-------------------------------------------------------------------|
| organization.data_residency_region | Must be one of a controlled enum:<br>us-east, eu-west             |
| user.email                         | Must be a valid email format, unique within the platform          |
| facility.country_code              | Must be a valid ISO 3166-1 alpha-2 code                           |
| line_item.quantity                 | Must be $\geq 0$                                                  |
| line_item.currency                 | Must be a valid ISO 4217 currency code                            |
| emission_factor.factor_value       | Must be $> 0$                                                     |
| calculation_result.scope           | Must be one of scope_1, scope_2_location, scope_2_market, scope_3 |
| report.status                      | Must follow the defined state machine (see §7.6)                  |

## 6.5 6.5 Data Dictionary (Excerpt)

| Table.Field                            | Type        | Description                                                                               |
|----------------------------------------|-------------|-------------------------------------------------------------------------------------------|
| document.status                        | enum        | Uploaded, Processing, Extracted, Matched, Calculated, Reviewed, Failed                    |
| document.ocr_confidence                | float (0-1) | Average OCR confidence score across the document                                          |
| line_item.extraction_confidence        | float (0-1) | LLM extraction confidence for the line item as a whole                                    |
| emission_factor_match.confidence_score | float (0-1) | Vector similarity-derived confidence of the factor match                                  |
| calculation_result.calculation_method  | enum        | spend_based, activity_based, hybrid                                                       |
| anomaly_flag.flag_type                 | enum        | low_match_confidence, statistical_outlier, missing_activity_data, manual_review_requested |
| report.status                          | enum        | Draft, Pending Review, Approved, Submitted, Amended                                       |

## 6.6 6.6 Sample Records (Illustrative)

### line\_item (sample)

| id      | description                       | quantity | unit  | unit_price | currency | extraction_confidence |
|---------|-----------------------------------|----------|-------|------------|----------|-----------------------|
| li_9f21 | Hot-rolled steel coil, grade S235 | 24.500   | tonne | 612.00     | EUR      | 0.94                  |

### calculation\_result (sample)

| id      | line_item_id | scope   | ghg_category               | co2e_kg   | calculation_method |
|---------|--------------|---------|----------------------------|-----------|--------------------|
| cr_4a11 | li_9f21      | scope_3 | Purchased Goods & Services | 46,655.00 | activity_based     |

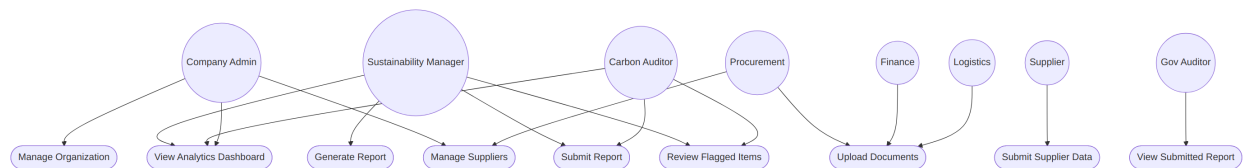
## 6.7 6.7 Data Retention

| Data Category                 | Retention Period                                                                | Rationale                      |
|-------------------------------|---------------------------------------------------------------------------------|--------------------------------|
| Source documents (S3)         | Life of tenant contract + 7 years                                               | Audit defensibility            |
| Calculation results           | Life of tenant contract + 7 years                                               | Regulatory reporting history   |
| Audit logs                    | 7 years minimum                                                                 | Regulatory / SOC 2 expectation |
| User session/auth logs        | 400 days                                                                        | Security investigation window  |
| Deleted-account personal data | Erased within 30 days of GDPR erasure request, subject to legal hold exceptions | GDPR Article 17                |

## 7 7. System Models

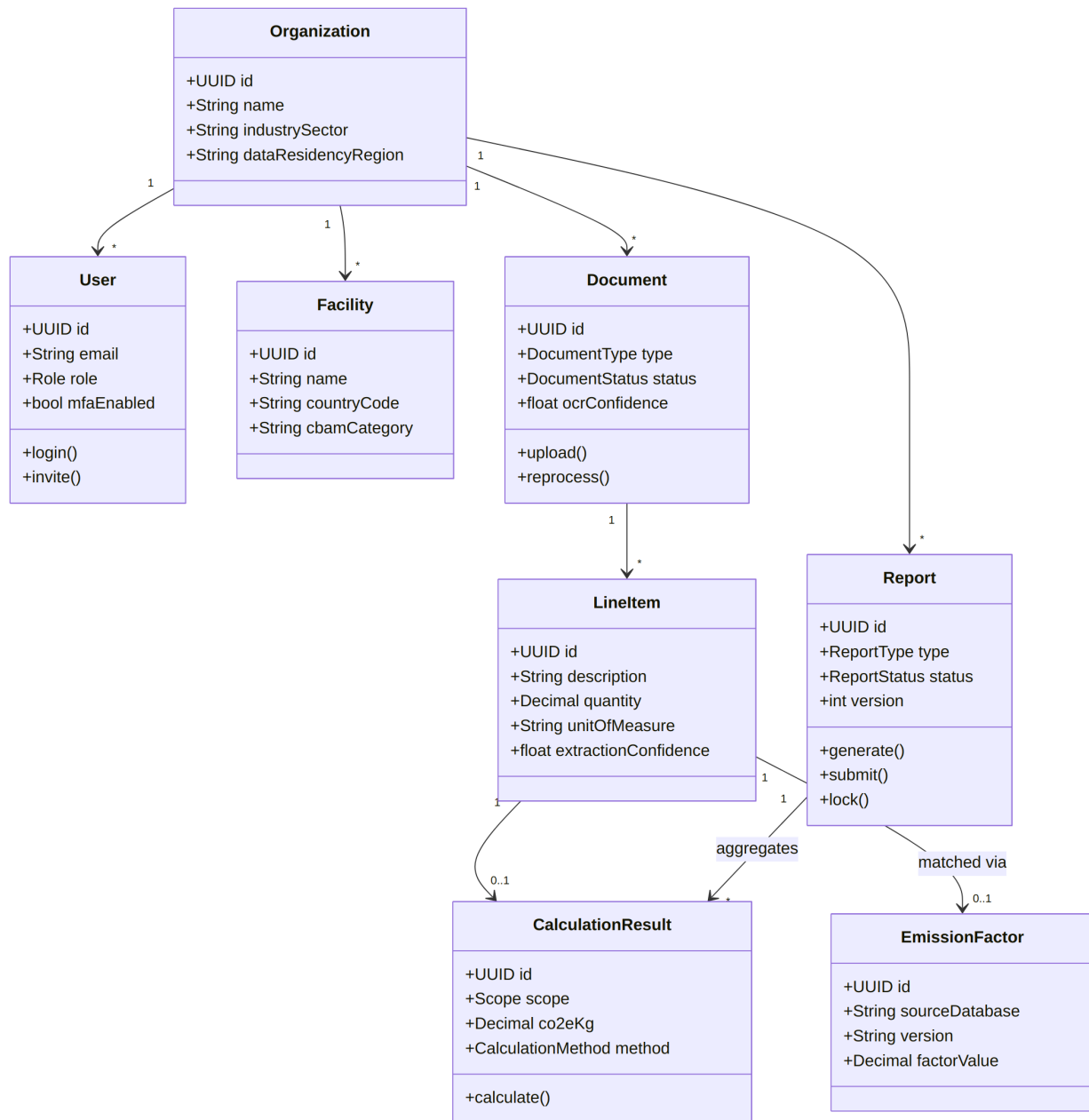
This chapter presents the remaining UML and architectural models. The System Context Diagram (Figure 2.1), Business Process Flow (Figure 2.2), Actor Context Diagram (Figure 2.3), Entity Relationship Diagram (Figure 6.1), and the illustrative Sequence Diagram (Figure 3.1) appear in their respective chapters above.

### 7.1 7.1 Use Case Diagram



**Figure 7.1 — Use Case Diagram**

## 7.2 Class Diagram (Core Domain Model)



**Figure 7.2 — Core Domain Class Diagram**



### 7.3 Activity Diagram — Document Processing Pipeline

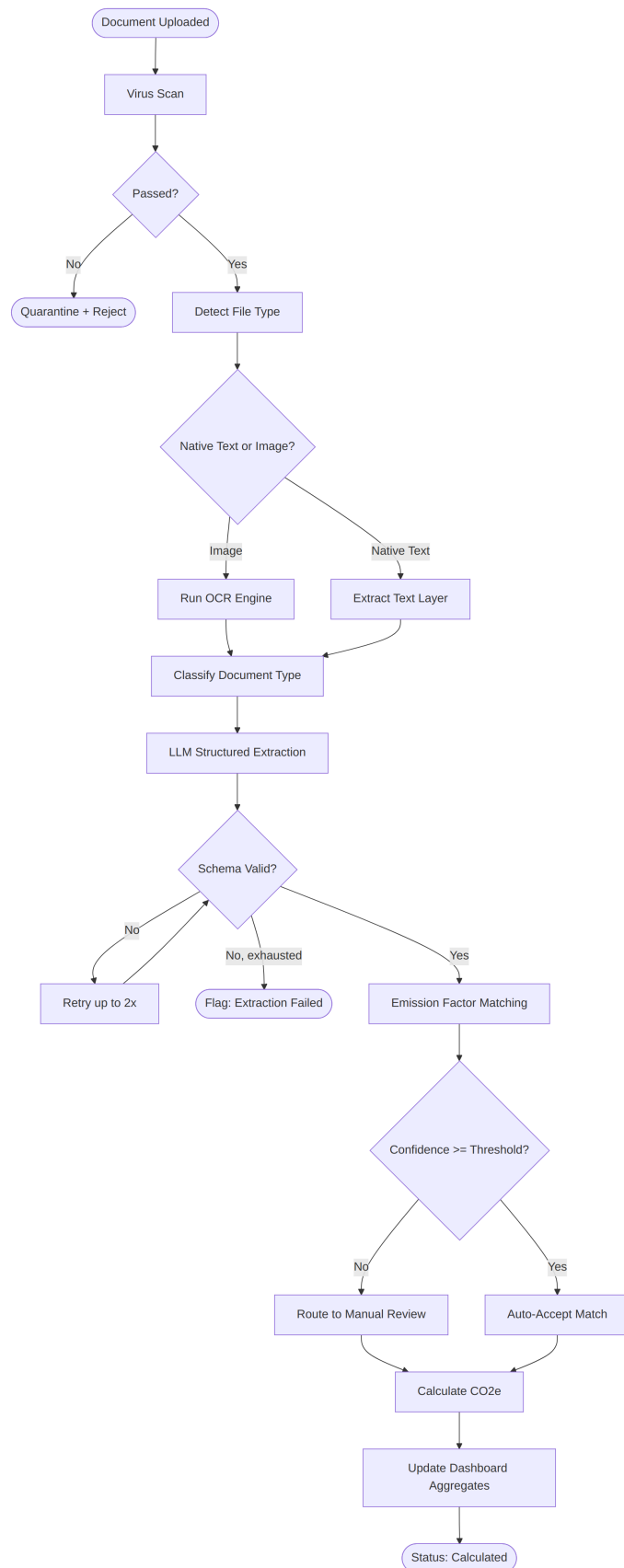


Figure 7.3 – Document Processing Activity Diagram

7.4 7.4 Component Diagram

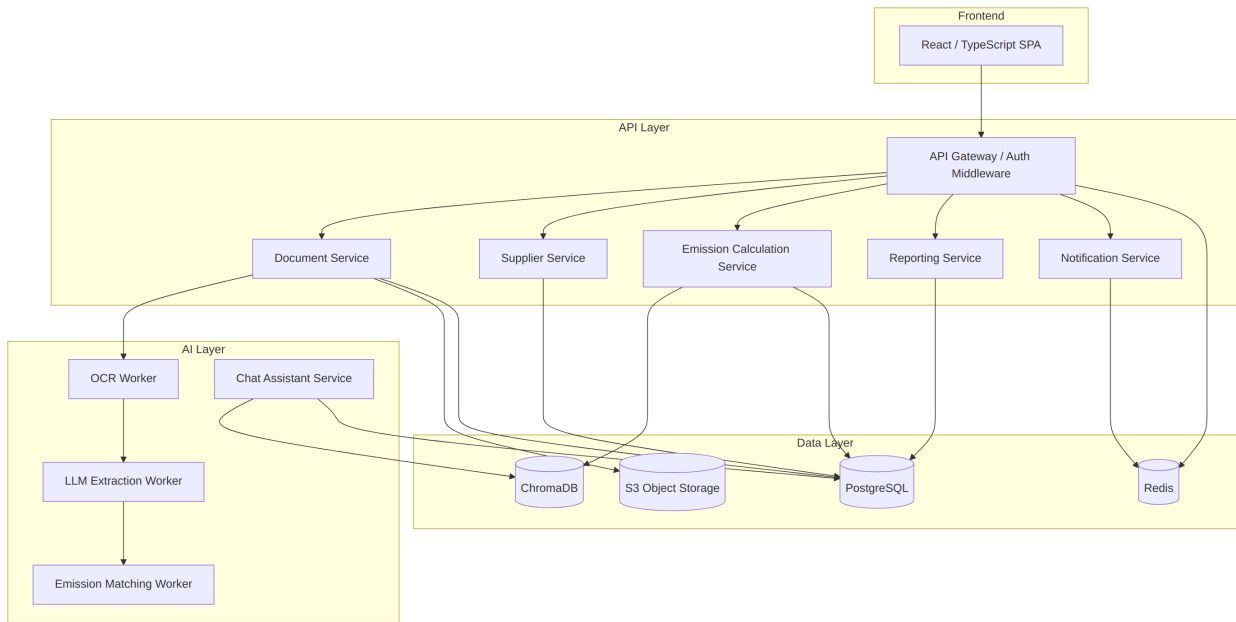


Figure 7.4 – Component Diagram

7.5 7.5 Deployment Diagram

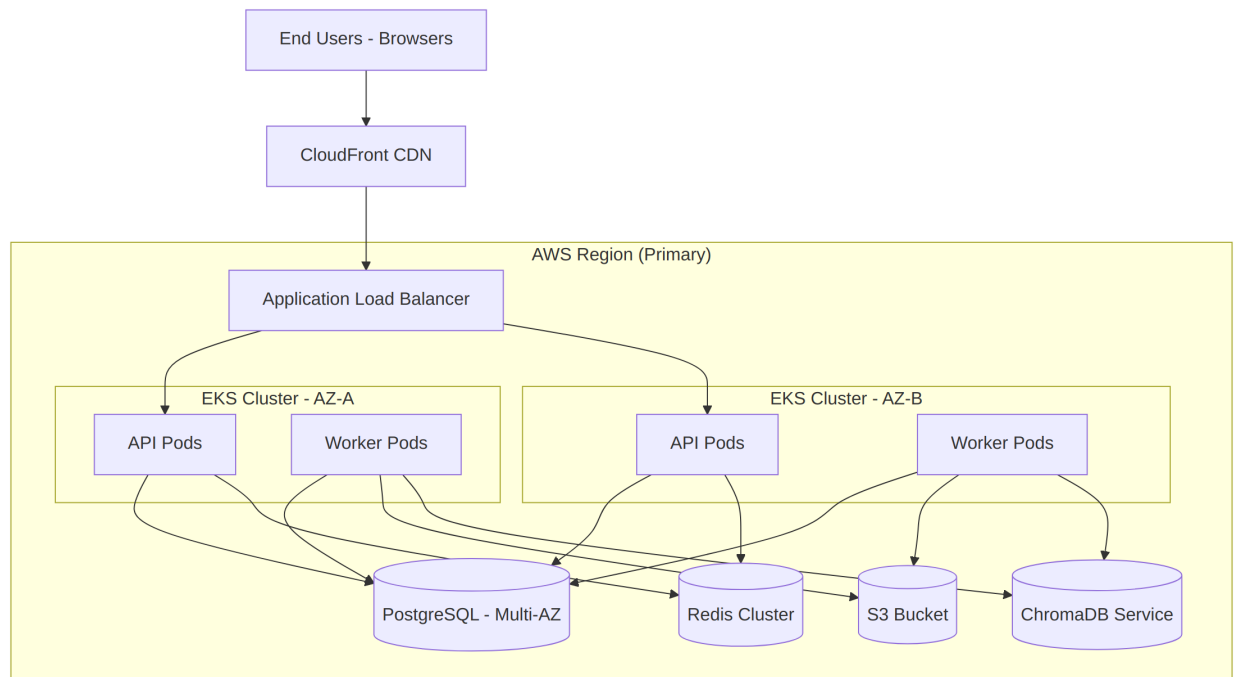


Figure 7.5 – Deployment Diagram



## 7.6 State Diagram — Report Lifecycle

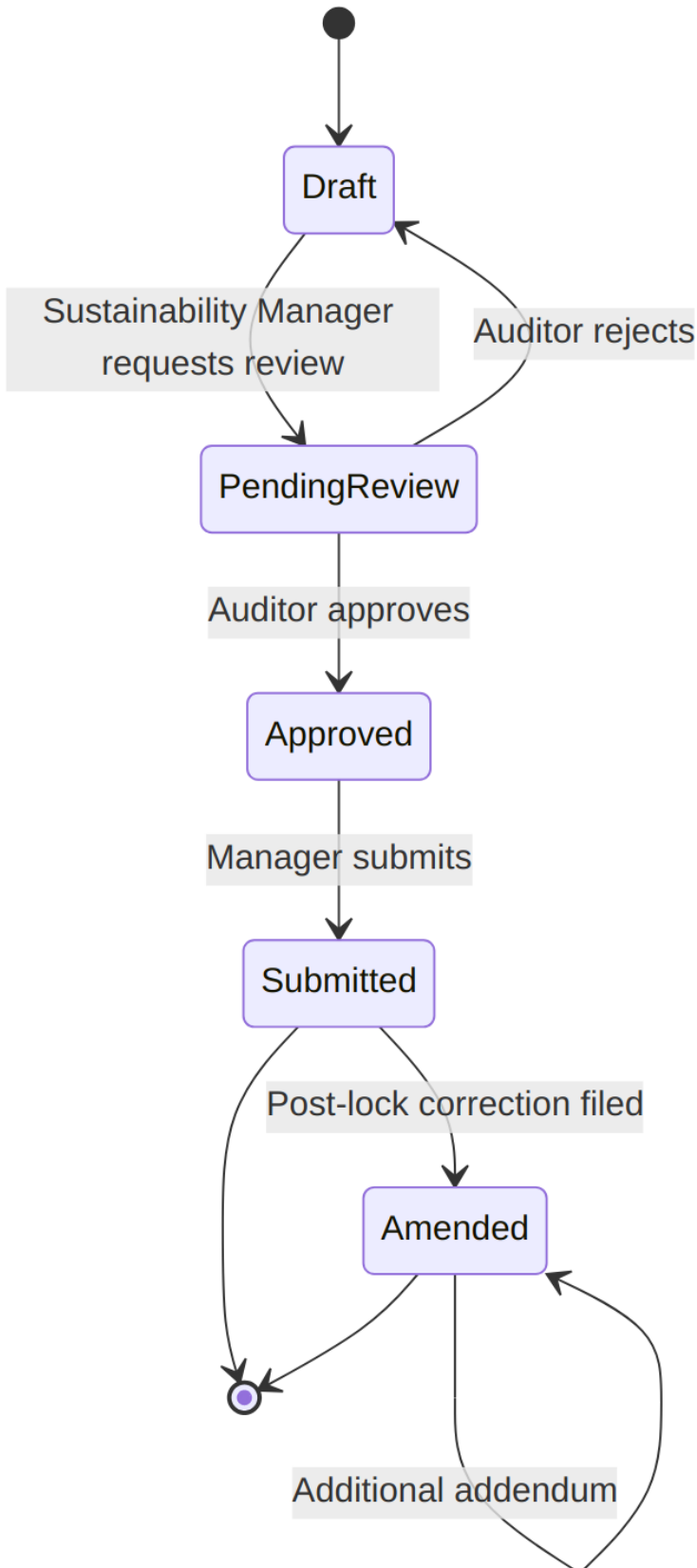


Figure 7.6 — Report Lifecycle State Diagram

7.7 7.7 Data Flow Diagram — Level 0 (Context)

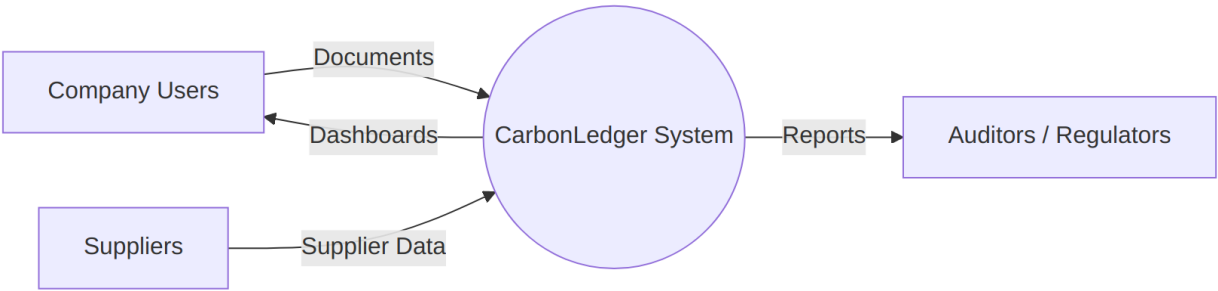


Figure 7.7 — Level 0 Data Flow Diagram

7.8 7.8 Data Flow Diagram — Level 1 (Major Processes)

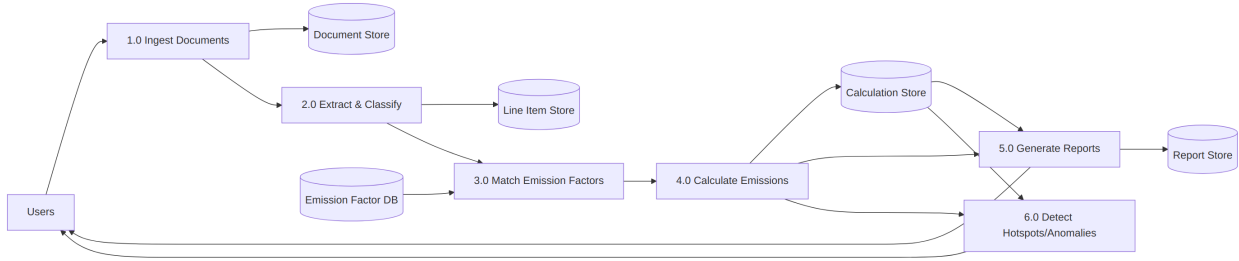


Figure 7.8 — Level 1 Data Flow Diagram

7.9 7.9 Data Flow Diagram — Level 2 (Extraction & Matching Detail)

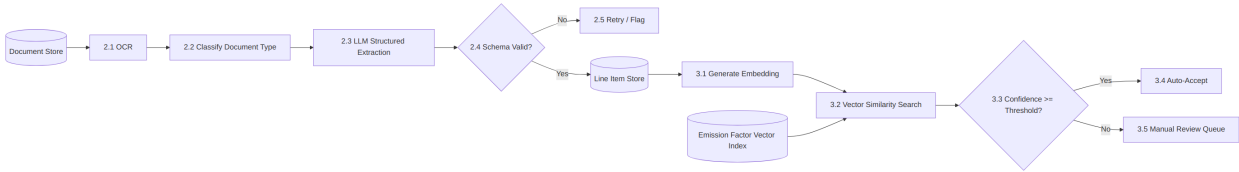


Figure 7.9 — Level 2 Data Flow Diagram

7.10 7.10 Package Diagram

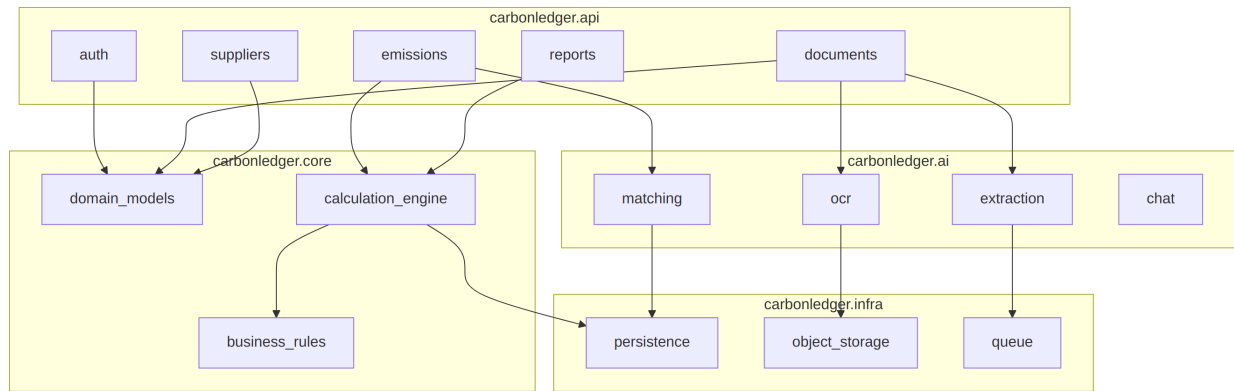


Figure 7.10 — Package Diagram

7.11 7.11 High-Level Architecture Diagram

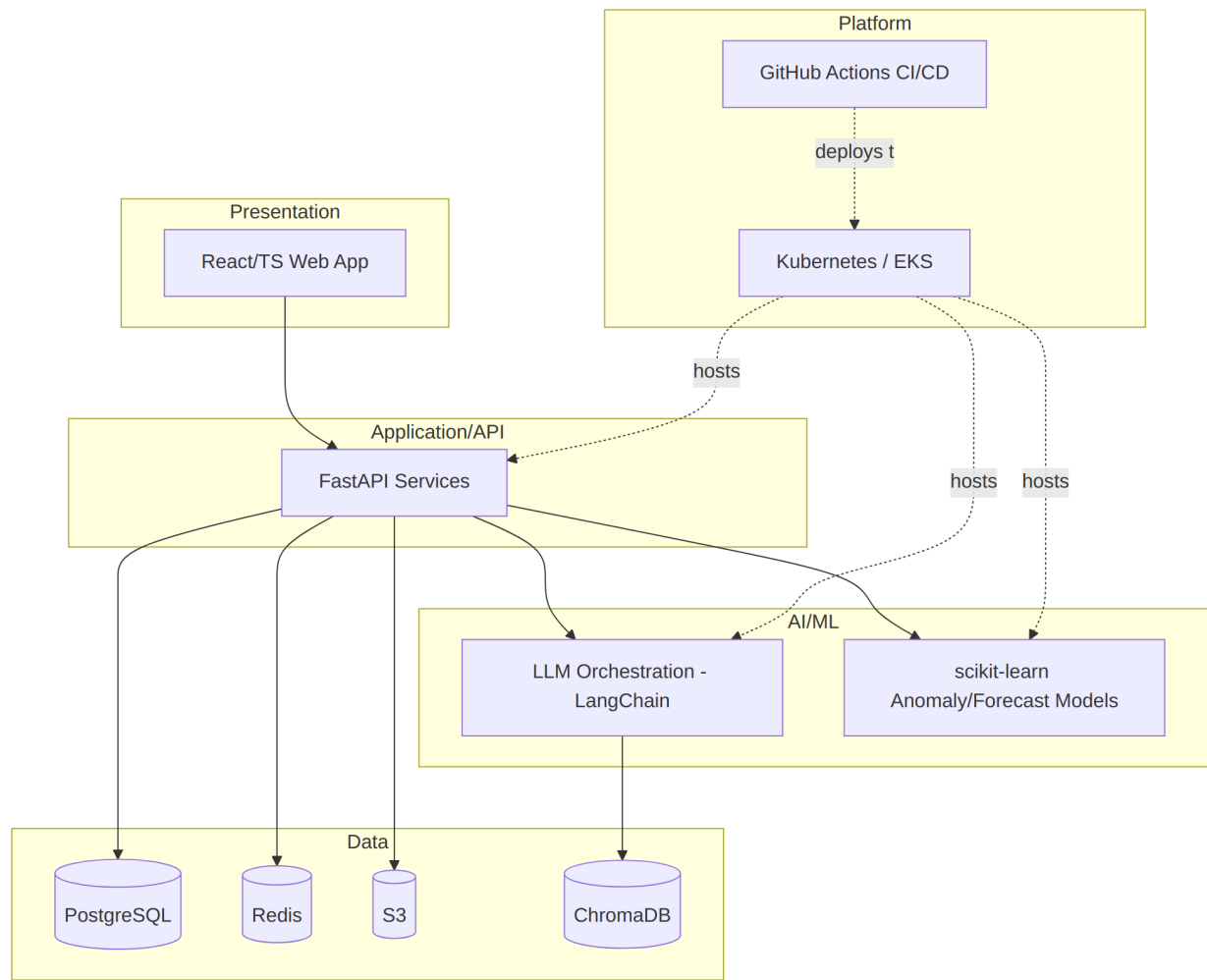


Figure 7.11 — High-Level Architecture Diagram

## 8. Security Requirements

### 8.1 Authentication

- SEC-AUTH-01: All user authentication shall use bcrypt/argon2 password hashing (never reversible encryption or plaintext).
- SEC-AUTH-02: The platform shall support OAuth 2.1-based SSO with Google Workspace and Microsoft Entra ID.
- SEC-AUTH-03: Multi-factor authentication (TOTP) shall be mandatory for Company Administrator, Sustainability Manager, and Carbon Auditor roles.

### 8.2 Authorization

- SEC-AUTHZ-01: Authorization shall be enforced via RBAC with server-side checks on every API call, independent of any client-side role display logic.
- SEC-AUTHZ-02: All database queries shall be scoped by `organization_id` at the ORM/query-builder level via a mandatory tenant-context filter, preventing accidental cross-tenant reads even under application bugs.

### 8.3 JWT & Token Management

- SEC-JWT-01: Access tokens are short-lived JWTs ( $\leq 15$  min TTL), signed with RS256, containing user ID, organization ID, and role claims only (no PII beyond email).
- SEC-JWT-02: Refresh tokens are opaque, stored hashed server-side, rotated on each use, and revocable individually or platform-wide per organization.

### 8.4 OAuth

- SEC-OAUTH-01: SSO integrations use the OAuth 2.1 Authorization Code flow with PKCE; implicit flow is prohibited.

### 8.5 RBAC Enforcement Matrix (Excerpt)

| Action                   | Admin | Sust.<br>Mgr | Auditor | Procurement      | Finance          | Logistics        | Supplier | Gov<br>Auditor         |
|--------------------------|-------|--------------|---------|------------------|------------------|------------------|----------|------------------------|
| Upload documents         | Yes   | Yes          | —       | Yes              | Yes              | Yes              | —        | —                      |
| View calculations        | Yes   | Yes          | Yes     | Own uploads only | Own uploads only | Own uploads only | —        | Submitted reports only |
| Override emission factor | Yes   | Yes          | Yes     | —                | —                | —                | —        | —                      |

| Action          | Admin | Sust.<br>Mgr | Auditor | Procurement | Finance | Logistics | Supplier | Gov<br>Auditor |
|-----------------|-------|--------------|---------|-------------|---------|-----------|----------|----------------|
| Generate report | Yes   | Yes          | —       | —           | —       | —         | —        | —              |
| Submit report   | —     | Yes          | Yes     | —           | —       | —         | —        | —              |
| Manage users    | Yes   | —            | —       | —           | —       | —         | —        | —              |
| View audit log  | Yes   | —            | Yes     | —           | —       | —         | —        | —              |

## 8.6 8.6 Encryption

- SEC-ENC-01: Data in transit encrypted with TLS 1.2 minimum, TLS 1.3 preferred.
- SEC-ENC-02: Data at rest encrypted with AES-256 (S3 SSE-KMS, PostgreSQL disk-level encryption).
- SEC-ENC-03: Application-level encryption for particularly sensitive fields (API keys, MFA secrets) using envelope encryption via AWS KMS, in addition to disk-level encryption.

## 8.7 8.7 Data Protection

- SEC-DP-01: Personal data (user account PII) is minimized to what is operationally necessary: name, work email, role. No unnecessary personal data collection.
- SEC-DP-02: Document contents (which may incidentally contain business-sensitive or personal data, e.g., a named contact on an invoice) are treated as confidential customer data, never used to train shared/foundation models without explicit contractual opt-in.

## 8.8 8.8 GDPR

- SEC-GDPR-01: Data Processing Agreements (DPAs) shall be available for all customers; CarbonLedger acts as processor, customer as controller.
- SEC-GDPR-02: The platform shall provide self-service and support-assisted workflows for data subject access, rectification, and erasure requests within the 30-day statutory window.
- SEC-GDPR-03: Sub-processors (LLM providers, cloud hosting) shall be disclosed in a public sub-processor list, with customer notification on any change.

## 8.9 8.9 Audit Logs

- SEC-AUD-01: Security-relevant events (login, MFA changes, permission changes, data export, impersonation) are logged separately from business audit logs and retained per NFR-LOG-01.

- SEC-AUD-02: Audit logs are write-once (append-only), stored in a manner that prevents modification even by database administrators (e.g., separate write-only role, periodic hash-chaining for tamper evidence).

## 8.10 8.10 Threat Model (Summary)

| Threat                                          | Mitigation                                                                                                                                                   |
|-------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Cross-tenant data leakage                       | Mandatory tenant-scoping middleware + automated cross-tenant isolation test suite                                                                            |
| Prompt injection via malicious document content | LLM extraction prompts use structured output constraints and never execute instructions found within document text; output is schema-validated, not executed |
| Credential stuffing / brute force               | Rate limiting, account lockout, MFA                                                                                                                          |
| Malicious file upload                           | Virus scanning, strict MIME allow-listing, sandboxed processing workers                                                                                      |
| Man-in-the-middle                               | TLS everywhere, HSTS enforced                                                                                                                                |
| Insider threat (Super Admin misuse)             | Time-boxed, audited impersonation; least-privilege internal access; audit log immutability                                                                   |
| API abuse / scraping                            | Rate limiting, API key scoping, anomaly-based abuse detection                                                                                                |
| Supply-chain (dependency) compromise            | Automated SCA scanning in CI, pinned dependency versions, signed container images                                                                            |

## 8.11 8.11 OWASP Top 10 (2021) Mitigation Mapping

| OWASP Category                     | Mitigation Approach                                                                         |
|------------------------------------|---------------------------------------------------------------------------------------------|
| A01 Broken Access Control          | Server-side RBAC + tenant scoping (§8.2)                                                    |
| A02 Cryptographic Failures         | TLS + AES-256 + KMS envelope encryption (§8.6)                                              |
| A03 Injection                      | Parameterized queries via ORM; strict schema validation on all inputs including LLM outputs |
| A04 Insecure Design                | Threat modeling performed per major feature during design review                            |
| A05 Security Misconfiguration      | Infrastructure as code, no manual prod changes, hardened container base images              |
| A06 Vulnerable/Outdated Components | Automated SCA/dependency scanning in CI/CD                                                  |

| OWASP Category                               | Mitigation Approach                                                                             |
|----------------------------------------------|-------------------------------------------------------------------------------------------------|
| A07 Identification & Authentication Failures | MFA, rate limiting, secure session/token management                                             |
| A08 Software & Data Integrity Failures       | Signed container images, CI provenance, immutable audit logs                                    |
| A09 Security Logging & Monitoring Failures   | Centralized structured logging, alerting on anomalous access patterns                           |
| A10 Server-Side Request Forgery              | Strict egress allow-listing for any server-initiated outbound requests (e.g., webhook delivery) |

## 8.12 8.12 API Security

- SEC-API-01: All API endpoints require authentication except explicitly public endpoints (registration, login, SSO callback).
- SEC-API-02: Rate limiting is applied per API key/user (default: 600 requests/minute) with 429 responses and Retry-After headers.
- SEC-API-03: All API inputs are validated against strict JSON Schemas before business logic execution.

## 8.13 8.13 Secure File Upload

- SEC-UP-01: Uploaded files are scanned for malware prior to persistence; infected files are quarantined and never reach processing workers.
- SEC-UP-02: File type is validated by content inspection (magic bytes), not solely by file extension or declared MIME type.
- SEC-UP-03: Uploaded files are processed in isolated, least-privilege worker containers with no outbound network access beyond required AI provider endpoints.

## 9. Performance & Quality

### 9.1 Availability, Scalability, and Fault Tolerance

The platform is designed for zero single points of failure at the application tier. All API and worker services are stateless and horizontally scaled; state lives exclusively in PostgreSQL (Multi-AZ), Redis (clustered), S3 (11 nines durability), and ChromaDB (replicated). Kubernetes liveness/readiness probes ensure unhealthy pods are automatically cycled out of the load-balancer rotation. Circuit breakers around the LLM provider calls prevent cascading failure if OpenAI or Gemini degrade; the secondary provider takes over automatically per NFR-REL-03.

### 9.2 Load Balancing & Caching

- An Application Load Balancer distributes traffic across API pods in multiple Availability Zones.
- Redis caches: (a) frequently accessed reference data (emission factor catalog metadata), (b) session/token blacklists, (c) pre-aggregated dashboard summaries refreshed on calculation completion, and (d) rate-limit counters.
- Materialized views in PostgreSQL back the analytics dashboard to avoid expensive on-the-fly aggregation across large transaction volumes.

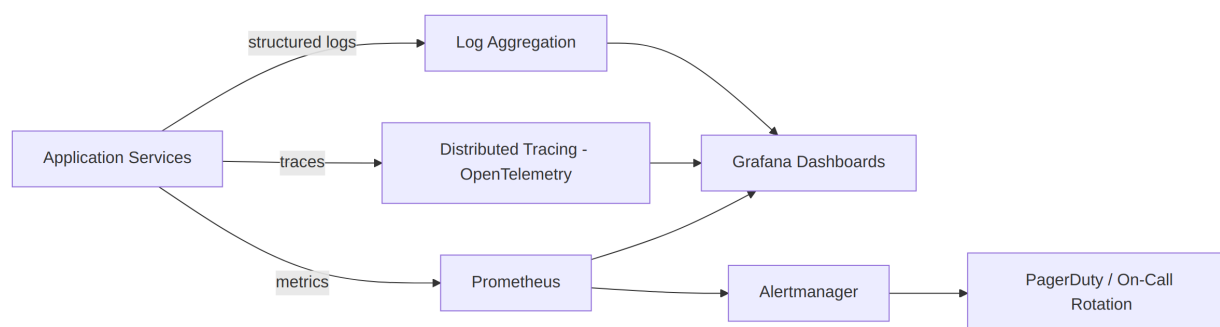
### 9.3 Performance Benchmarks

| Benchmark                                   | Target            | Test Method                                         |
|---------------------------------------------|-------------------|-----------------------------------------------------|
| Document extraction pipeline (single doc)   | $\leq 30s$ p95    | Synthetic load test, 1,000-document sample          |
| Bulk batch (500 docs)                       | $\leq 60$ minutes | Load test against worker pool at target concurrency |
| Dashboard load (100K transactions/year org) | $\leq 2s$ p95     | Synthetic tenant with seeded data                   |
| API p95 latency (non-AI)                    | $\leq 300ms$      | k6/Locust load test at 200 RPS sustained            |
| Report generation                           | $\leq 60s$ p95    | Load test across representative org sizes           |

### 9.4 Quality Metrics & Code Quality

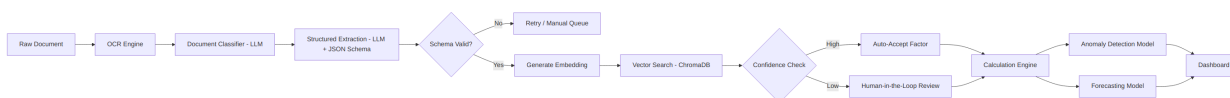
- QM-01: Minimum 80% automated unit/integration test coverage on the calculation engine and matching engine (highest-risk business logic).
- QM-02: All pull requests require passing CI (lint, type-check, unit tests, SCA scan) and at least one peer review before merge.
- QM-03: Static analysis (mypy/type checking on Python, ESLint/TypeScript strict mode on frontend) enforced in CI as a merge gate.
- QM-04: Extraction and matching model quality tracked via a labeled golden dataset, re-evaluated on every model/prompt version change, with regression alerts if F1 drops more than 2 points.

## 9.5 9.5 Monitoring & Observability Architecture



**Figure 9.1 — Monitoring Architecture**

## 9.6 9.6 AI / ML Pipeline Architecture



**Figure 9.2 — AI / ML Pipeline**

## 9.7 9.7 Disaster Recovery Plan

| Element            | Approach                                                           |
|--------------------|--------------------------------------------------------------------|
| RPO                | ≤ 15 minutes via continuous WAL streaming to standby               |
| RTO                | ≤ 4 hours for full regional failover                               |
| Backup cadence     | Continuous WAL + daily full snapshot, 35-day retention             |
| Failover testing   | Semi-annual live/tabletop DR exercise, documented and reviewed     |
| Communication plan | Status page updates within 15 minutes of a P1 incident declaration |

## 9.8 9.8 Capacity Planning (Launch-Year Assumptions)

| Metric                 | Assumption                                                                 |
|------------------------|----------------------------------------------------------------------------|
| Tenants at GA          | 50-150 (pilot to early GA)                                                 |
| Documents/tenant/month | 500-5,000                                                                  |
| Peak concurrent users  | 300                                                                        |
| Storage growth         | ~2 GB/tenant/year (documents + derived data)                               |
| LLM API call volume    | ~3 calls/document average (classification + extraction + occasional retry) |

## 9.9 9.9 Cost Assumptions (Illustrative, Non-Binding)

| Cost Category             | Driver                                                  | Notes                                                                      |
|---------------------------|---------------------------------------------------------|----------------------------------------------------------------------------|
| LLM API usage             | Per-document extraction calls                           | Largest variable cost; scales with revenue-generating usage                |
| Compute (EKS)             | Baseline + autoscaled worker pods                       | Right-sized via HPA to avoid idle overprovisioning                         |
| Storage (S3 + PostgreSQL) | Document volume + retention policy                      | Grows predictably with tenant count and history depth                      |
| Third-party OCR           | If a managed OCR service is used instead of self-hosted | Evaluated against self-hosted Tesseract-class alternative for cost control |

## 9.10 9.10 Future Roadmap (Indicative)

| Horizon      | Theme                                                                                                        |
|--------------|--------------------------------------------------------------------------------------------------------------|
| 0-6 months   | GA launch, SAP/Oracle/Dynamics integrations, SOC 2 Type I                                                    |
| 6-12 months  | Primary supplier LCA data ingestion, expanded OCR languages, SOC 2 Type II                                   |
| 12-18 months | What-if scenario modeling, carbon-credit marketplace evaluation, EU multi-region deployment                  |
| 18-24 months | On-premises/private-cloud option for large enterprise, expanded CBAM goods coverage as EU regulation evolves |

## **10 10. Acceptance Criteria**

### **10.1 10.1 Functional Acceptance**

- FA-01: 100% of Must-Have functional requirements in Chapter 3 pass their stated acceptance criteria in a controlled staging environment prior to GA release.
- FA-02: All user roles defined in §2.7 can complete their primary workflow end-to-end without engineering intervention.
- FA-03: Zero P1 (blocking) defects open at release candidate sign-off.

### **10.2 10.2 Performance Acceptance**

- PA-01: All benchmarks in §9.3 are met under sustained load testing at 2x expected launch concurrency.
- PA-02: No performance regression greater than 10% between release candidates, verified by automated performance regression testing in CI.

### **10.3 10.3 Security Acceptance**

- SA-01: An independent third-party penetration test is completed with no unresolved Critical or High findings prior to GA.
- SA-02: 100% of OWASP Top 10 mitigations in §8.11 are verified via automated and manual test cases.
- SA-03: Cross-tenant isolation test suite (adversarial) passes with zero data leakage across 100% of tested endpoints.

### **10.4 10.4 Integration Testing**

- IT-01: SAP, Oracle ERP Cloud, and Microsoft Dynamics 365 integrations successfully complete a full import cycle (POs, invoices, supplier master) against each vendor's sandbox environment.
- IT-02: LLM provider failover (OpenAI → Gemini) completes without user-visible failure during a simulated primary-provider outage.

### **10.5 10.5 User Acceptance Testing (UAT)**

- UAT-01: At least 3 pilot customers complete a full onboarding-to-first-report cycle in a UAT environment and formally sign off.
- UAT-02: System Usability Scale (SUS) score  $\geq 75$  across UAT participants (per NFR-USE-01).
- UAT-03: At least one participating Carbon Auditor confirms that report line items are fully traceable to source documents.

### **10.6 10.6 Regression Testing**

- RT-01: Full automated regression suite (unit + integration + critical-path end-to-end) executes on every release candidate with 100% pass rate as a release

gate.

- RT-02: Historical report reproducibility is verified: re-running a prior calculation without a factor-database update reproduces bit-identical results.

## **10.7 10.7 AI Model Validation**

- AI-VAL-01: Document classification accuracy  $\geq 96\%$  on the held-out labeled validation set (per FR-AI-01).
- AI-VAL-02: Structured extraction field-level F1  $\geq 93\%$  on the held-out validation set (per FR-AI-02).
- AI-VAL-03: Emission factor auto-match agreement with expert auditor labeling  $\geq 95\%$  (per FR-EF-01).
- AI-VAL-04: Model/prompt version changes are never promoted to production without passing the golden-dataset regression gate (per QM-04).

## **10.8 10.8 Deployment Acceptance**

- DA-01: Infrastructure is fully defined as code and deployable to a clean environment via CI/CD without manual steps.
- DA-02: Health checks, monitoring dashboards, and on-call alerting (Chapter 9) are operational and validated via a simulated incident before GA.
- DA-03: A documented, tested rollback procedure exists for every deployable service.

## 11 11. Appendices

### 11.1 11.1 Glossary

| Term                  | Definition                                                                                                         |
|-----------------------|--------------------------------------------------------------------------------------------------------------------|
| Activity-Based Method | Emissions calculation using physical activity data (e.g., liters of fuel, tonnes shipped) rather than spend amount |
| Anomaly Flag          | A system-generated marker indicating a line item requires human review before it can flow into a final report      |
| CBAM                  | Carbon Border Adjustment Mechanism; EU regulation on embedded carbon in imported goods                             |
| CO <sub>2</sub> e     | Carbon dioxide equivalent                                                                                          |
| Data Residency        | The geographic region in which a tenant's data is stored and processed                                             |
| Embedding             | A numerical vector representation of text used for semantic similarity search                                      |
| Emission Factor       | Coefficient converting an activity quantity into CO <sub>2</sub> e                                                 |
| GHG Protocol          | The most widely used international accounting standard for corporate GHG emissions                                 |
| Hotspot               | A supplier, product, or lane responsible for a disproportionate share of emissions                                 |
| ISO 14064             | International standard for quantification and reporting of GHG emissions                                           |
| RBAC                  | Role-Based Access Control                                                                                          |
| Scope 1/2/3           | GHG Protocol emission categories: direct, purchased-energy, and value-chain emissions respectively                 |
| Spend-Based Method    | Emissions calculation using monetary spend and an economic-input-output-derived factor                             |
| Tenant                | A distinct customer organization in the multi-tenant platform                                                      |

### 11.2 11.2 References

See §1.8 for the full reference table [R1]–[R10].

### 11.3 11.3 Revision History

See Document Control section on the cover page for the authoritative revision history.

## 11.4 Risk Register

| ID      | Risk                                                               | Likelihood | Impact   | Mitigation                                                                              | Owner              |
|---------|--------------------------------------------------------------------|------------|----------|-----------------------------------------------------------------------------------------|--------------------|
| RISK-01 | LLM extraction accuracy insufficient for audit-grade defensibility | Medium     | High     | Human-in-the-loop review for low-confidence items; continuous golden-dataset evaluation | Engineering        |
| RISK-02 | EU CBAM schema changes during regulatory transition period         | High       | Medium   | Schema-driven report templates configurable without code changes (FR-CALC-04)           | Product/Compliance |
| RISK-03 | LLM provider outage or pricing change                              | Medium     | Medium   | Multi-provider failover architecture (NFR-REL-03); usage-based cost monitoring          | Engineering        |
| RISK-04 | Cross-tenant data leakage                                          | Low        | Critical | Mandatory tenant-scoping middleware, adversarial isolation testing (SA-03)              | Security           |

| ID      | Risk                                                     | Likelihood | Impact | Mitigation                                                                                      | Owner                  |
|---------|----------------------------------------------------------|------------|--------|-------------------------------------------------------------------------------------------------|------------------------|
| RISK-05 | Slow customer adoption due to ERP integration complexity | Medium     | High   | Generic CSV/SFTP fallback path in addition to native ERP connectors                             | Product                |
| RISK-06 | Emission factor database licensing/availability changes  | Low        | Medium | Reliance on multiple public sources (DEFRA, EPA, GHG Protocol) reduces single-source dependency | Compliance             |
| RISK-07 | Regulatory scrutiny of AI-generated compliance figures   | Medium     | High   | Full lineage/traceability by design (BR-01); human sign-off required before submission (BR-02)  | Compliance/Legal       |
| RISK-08 | Key-person dependency in ML/AI team                      | Low        | Medium | Documentation pair-programming, golden-dataset-driven reproducibility over tribal knowledge     | Engineering Leadership |

## 11.5 Requirement Traceability Matrix (Excerpt)

| Requirement ID | Description (short)           | Design Reference                    | Test Case ID | Acceptance Criteria Ref |
|----------------|-------------------------------|-------------------------------------|--------------|-------------------------|
| FR-AUTH-02     | MFA login                     | §3.1, Component Diagram (Fig. 7.4)  | TC-AUTH-002  | AC-1, AC-2              |
| FR-DOC-01      | Multi-format upload           | §3.4, Deployment Diagram (Fig. 7.5) | TC-DOC-001   | AC-1, AC-2              |
| FR-AI-02       | Structured extraction         | §3.6, AI Pipeline (Fig. 9.2)        | TC-AI-002    | AC-1, AC-2              |
| FR-EF-01       | Emission factor matching      | §3.7, ERD (Fig. 6.1)                | TC-EF-001    | AC-1, AC-2              |
| FR-CALC-04     | CBAM embedded emissions       | §3.8                                | TC-CALC-004  | AC-1, AC-2              |
| FR-RPT-02      | CBAM report generation        | §3.11, State Diagram (Fig. 7.6)     | TC-RPT-002   | AC-1                    |
| FR-AUD-01      | Immutable audit trail         | §3.13                               | TC-AUD-001   | AC-1, AC-2              |
| NFR-SEC-01     | Encryption in transit/at rest | Chapter 8                           | TC-SEC-001   | SA-01, SA-02            |
| NFR-PERF-01    | Dashboard load time           | Chapter 5, 9                        | TC-PERF-001  | PA-01                   |

*The complete Requirement Traceability Matrix, mapping all ~60 functional and non-functional requirements to design artifacts and test cases, is maintained as a living document in the engineering test-management system and is available on request.*

## 11.6 11.6 Assumptions (Consolidated)

See §2.8 for the full assumptions list (AS-01 through AS-06).

## 11.7 11.7 Future Scope

See §2.12 (Future Enhancements) and §9.10 (Future Roadmap).

## 11.8 11.8 Abbreviations

See §1.7 for the full acronym table.

**11.9 11.9 Approval**

| Role                     | Name | Signature | Date |
|--------------------------|------|-----------|------|
| Chief Technology Officer |      |           |      |
| Head of Product          |      |           |      |
| Head of Compliance       |      |           |      |
| Lead Solution Architect  |      |           |      |

— *End of Document* —